



Bruno Lima Giacomi

Modelagem de Ameaças em Ambientes de Nuvem: Uma Abordagem Baseada em Inteligência Artificial

São Caetano do Sul 2026

Bruno Lima Giacomi

Modelagem de Ameaças em Ambientes de Nuvem: Uma Abordagem Baseada em Inteligência Artificial

Trabalho de Graduação apresentado à Faculdade de Tecnologia de São Caetano do Sul, como requisito parcial para a obtenção do grau de Tecnólogo em Segurança da Informação.

Orientador: Prof. Mestre Kleber da Silva Divino.

São Caetano do Sul 2026

FICHA DE AVALIAÇÃO

BRUNO LIMA GIACOMI

Data de Aprovação ____/____/____

Nota: _____

Profº. (a) Dr. (a) _____

(Assinatura)

Profº. (a) Dr. (a) _____

(Assinatura)

Profº. (a) Dr. (a) _____

(Assinatura)

AGRADECIMENTOS

A Faculdade de Tecnologia Fatec Antônio Russo e todo seu corpo docente e funcionários, por todo o carinho que nos deram durante todo o curso.

Em especial ao Profº Mestre Kleber da Silva Divino, por toda atenção dada nesses dois semestres e também pela confiança depositada em meu trabalho. Também agradeço a Eladia Penteado e ao Henrique, seu marido, pela grande ajuda que eles me deram na elaboração deste trabalho.

Por fim, registro minhas homenagens póstumas ao estimado professor e mestre Mário Eugênio Longato, cuja memória permanece viva em nossos corações, refletida na alegria que transmitia diariamente, seja como docente, coordenador ou amigo.

Epígrafe

“A atividade mais importante que um ser humano pode alcançar é aprender para entender, porque entender é ser livre.”

(Baruch Shpinoza)

RESUMO

A crescente complexidade das arquiteturas em nuvem e o aumento da superfície de ataque tornam a modelagem de ameaças uma atividade essencial no desenvolvimento de sistemas seguros. No entanto, abordagens tradicionais demandam elevado esforço manual, conhecimento especializado e apresentam limitações de escalabilidade. Este trabalho investiga o uso de Inteligência Artificial Generativa como suporte ao processo de modelagem de ameaças, com foco na metodologia STRIDE, em ambientes de computação em nuvem.

A pesquisa adota uma abordagem experimental e aplicada, baseada no desenvolvimento de um protótipo funcional implementado na Amazon Web Services (AWS). A solução integra serviços gerenciados, como AWS Lambda, Amazon S3, Amazon Cognito, AWS AppSync e Amazon Bedrock, utilizando modelos de linguagem para análise automatizada de arquiteturas descritas como Diagramas de Fluxo de Dados (DFD). O sistema emprega técnicas de *few-shot prompting* para interpretar os diagramas e gerar ameaças classificadas segundo o modelo STRIDE.

Durante os experimentos, foram conduzidos múltiplos cenários de teste, com coleta de dados de entrada e saída, métricas de desempenho e custos operacionais. Os resultados indicam que a abordagem proposta é tecnicamente viável e capaz de acelerar significativamente o processo de identificação de ameaças, mantendo um nível consistente de qualidade nas análises. Entretanto, observam-se limitações inerentes ao uso de modelos generativos, como variabilidade nas respostas, possibilidade de omissões e dependência da qualidade dos *prompts* e exemplos fornecidos.

Conclui-se que a integração de Inteligência Artificial Generativa ao processo de modelagem de ameaças representa uma abordagem promissora, especialmente como ferramenta de apoio a especialistas, e não como substituição completa da análise humana. O trabalho contribui ao demonstrar, de forma prática e mensurável, os benefícios, limitações e implicações dessa integração, incluindo aspectos técnicos, econômicos e de segurança.

Palavras-chave: Modelagem de Ameaças. STRIDE. Inteligência Artificial Generativa. Segurança em Nuvem. AWS. Segurança da Informação.

ABSTRACT

The increasing complexity of cloud architectures and the expansion of the attack surface make threat modeling an essential activity in the development of secure systems. However, traditional approaches require significant manual effort, specialized knowledge, and present scalability limitations. This work investigates the use of Generative Artificial Intelligence as a support mechanism for the threat modeling process, with a focus on the STRIDE methodology, in cloud computing environments.

The research adopts an experimental and applied approach, based on the development of a functional prototype implemented on Amazon Web Services (AWS). The solution integrates managed services such as AWS Lambda, Amazon S3, Amazon Cognito, AWS AppSync, and Amazon Bedrock, leveraging language models for automated analysis of architectures described as Data Flow Diagrams (DFD). The system employs few-shot prompting techniques to interpret the diagrams and generate threats classified according to the STRIDE model.

During the experiments, multiple test scenarios were conducted, with the collection of input and output data, performance metrics, and operational costs. The results indicate that the proposed approach is technically viable and capable of significantly accelerating the threat identification process, while maintaining a consistent level of analysis quality. However, limitations inherent to the use of generative models were observed, such as response variability, potential omissions, and dependence on the quality of prompts and provided examples.

It is concluded that integrating Generative Artificial Intelligence into the threat modeling process represents a promising approach, particularly as a support tool for specialists rather than a complete replacement for human analysis. This work contributes by demonstrating, in a practical and measurable manner, the benefits, limitations, and implications of this integration, including technical, economic, and security aspects.

Keywords: Threat Modeling; STRIDE; Generative Artificial Intelligence; Cloud Security; AWS; Information Security.

LISTA DE FIGURAS

Figura 1: Tríade CID.....	18
Figura 2: Arquitetura de Segurança AWS.....	23
Figura 3: Representação conceitual das camadas de IA, ML e <i>Deep Learning</i>	27
Figura 4: Diferença de treinamento de modelos de ML e <i>Deep Learning</i>	29
Figura 5: Benefícios de uma modelagem de ameaças seguindo o STRIDE.....	36
Figura 6: Representação de um DFD.....	39
Figura 7: Arquitetura proposta da solução.....	48
Figura 8: Tela de autenticação da aplicação.....	56
Figura 9: Tela de troca de senha da aplicação.....	57
Figura 10: Tela inicial da aplicação.....	57
Figura 11: Inserção de Dados	58
Figura 12: Extração dos componentes.....	59
Figura 13: Opção de novos componentes.....	59
Figura 14: Geração de ameaças, exportação e visualização.....	60
Figura 15: Edição dos Riscos	61
Figura 16: Ações sobre Riscos.....	62
Figura 17: Aba de resumo.....	63
Figura 18: Aba de Score.....	63
Figura 19: Aba de contendo todos os dados gerados.....	64
Figura 20: Arquitetura ID12.....	68
Figura 21: Detalhes do ID12.....	69
Figura 22: Arquitetura do ID15.....	70
Figura 23: Detalhes do ID15.....	71
Figura 24: Arquitetura do ID20.....	72
Figura 25: Detalhes do ID20.....	73

Figura 26: Arquitetura do ID2.....	74
Figura 27: Detalhes do ID2.....	75
Figura 28: Comparação do tempo de execução entre a abordagem manual e a abordagem baseada em IA nos testes selecionados.....	77
Figura 29: Comparação percentual da taxa de falsos positivos entre a abordagem manual e a abordagem baseada em IA nos cenários analisados.....	77
Figura 30: Custos do projeto entre outubro de 2025 e abril de 2026.....	79

LISTA DE TABELAS

Tabela 1 - Recomendações de Boas práticas da AWS.....	25
Tabela 2 - Lista de testes realizados.....	65
Tabela 3 - Comparação dos testes destacados.....	76

Sumário

1. Introdução	13
1.1 Objetivo geral	14
1.2 Objetivos Específicos	14
1.3. Justificativa	14
1.4. Público-alvo	16
1.5. Estrutura do Trabalho	16
2. Segurança da Informação	17
2.1. Governança, Normas e <i>Compliance</i>	18
2.2. Ameaças, vetores e modelagem	19
2.3. Controles e boas práticas	19
3. Segurança em Nuvem na AWS: Fundamentos, Arquitetura e Superfície de Ataque	21
3.1. Modelo de Responsabilidade Compartilhada da AWS	21
3.2. Arquitetura de Referência Segura na AWS	22
3.3. Vetores de Ataque e Exemplo de Incidentes na AWS	23
3.4. Controles e Boas Práticas Específicas para AWS	25
4. Inteligência Artificial Generativa e Segurança da Informação: Conceitos, Aplicações e Desafios	27
4.1. Fundamentos de Inteligência Artificial	27
4.2. Inteligência Artificial na Segurança da Informação	30
4.3. Riscos do uso de Inteligência Artificial em Segurança da Informação	31
5. Modelagem de Ameaças: Identificação, Classificação e Avaliação com STRIDE e DREAD	33
5.1. Modelo STRIDE para Identificação de Ameaças	34
5.2. Modelo DREAD para Avaliação de Riscos	36
5.3. Diagramas de Fluxo de Dados (DFD)	38
5.4. Limitações e Desafios da Modelagem de Ameaças	40
6. Metodologia	42
6.1. Tipo de pesquisa	42
6.2. Ambiente experimental	42
6.3. Utilização da Inteligência Artificial Generativa	42
6.4. Processo de modelagem de ameaças	43
6.5. Execução do experimento	43
6.6. Ambiente Tecnológico e Ferramentas Utilizadas	44
6.7. Limitações e considerações éticas	46
7. Arquitetura da Solução	48
7.1. Componentes	49
7.2. Fluxo de Processamento de dados da Solução	52
7.3. Aderência a Boas Práticas de Cloud (FinOps)	54
8. Passo a Passo de Execução e Outputs	56
8.1. Autenticação da Solução	56
8.2. Atualização de credenciais de acesso	57

8.3. Acesso inicial à aplicação e criação de novo cenário	57
8.4. Submissão de dados para modelagem de ameaças	58
8.5. Extração automática de componentes	58
8.6. Geração e visualização das ameaças	60
8.7. Edição e gestão das ameaças identificadas	60
8.8. Exportação dos resultados em formato estruturado	62
8.9. Considerações finais da demonstração	64
9. Análise dos Resultados obtidos	65
9.1. Comparação dos resultados	76
9.2. Análise de Custos da Abordagem Proposta	78
10. Conclusão	80
10.1. Comparação com abordagem manual	81
10.2. Limitações do trabalho	81
10.3. Trabalhos futuros	82
10.4. Considerações finais	82
Referências	83
Apêndice A - Guia de Implementação e Execução do Protótipo de Modelagem de Ameaças com IA Generativa	90
A.1. Visão Geral do Protótipo	90
A.2. Pré-requisitos do Ambiente	90
A.3. Implantação do Back-end	91
A.4. Configuração do Mecanismo de Modelagem (<i>Few-Shot Learning</i>)	92
A.5. Implantação do Front-end	92
A.5.3. Implantação em Produção	93
A.6. Atualização e Manutenção	93
A.7. Testes	93
Apêndice B - Disponibilização do Conjunto Completo dos Dados gerados nas 4 amostras representativas	94
Apêndice C - Disponibilização dos Dados Detalhados de Custos	95

1. Introdução

Com o avanço da transformação digital e a crescente adoção de ambientes em nuvem, empresas e instituições governamentais enfrentam desafios cada vez mais complexos relacionados à segurança da informação. A Amazon Web Services (AWS), por exemplo, tornou-se uma das plataformas mais procuradas por organizações devido à sua flexibilidade e variedade de serviços, que facilitam a criação e a rápida expansão de sistemas. No entanto, essa agilidade também aumenta a superfície de ataque, expondo ativos críticos a ameaças cibernéticas sofisticadas, como ataques direcionados a identidades, aplicações e infraestrutura.

Nesse contexto, a modelagem de ameaças se consolida como uma prática essencial no ciclo de vida do desenvolvimento seguro de software (*Secure Software Development Lifecycle* - SSDLC), ao permitir identificar e avaliar vulnerabilidades potenciais desde as fases iniciais do projeto. Entretanto, apesar de sua relevância, esse processo ainda é predominantemente manual, demandando elevado tempo, esforço analítico e conhecimento especializado por parte dos profissionais. Em ambientes dinâmicos e escaláveis, como os de computação em nuvem, esse fator pode se tornar um gargalo, dificultando a aplicação contínua e eficiente da modelagem de ameaças ao longo do ciclo de desenvolvimento.

A metodologia STRIDE, criada pela Microsoft, é amplamente conhecida por sua abordagem estruturada, que classifica ameaças em seis categorias principais: *Spoofing*, *Tampering*, *Repudiation*, *Information Disclosure*, *Denial of Service* e *Elevation of Privilege*. Essa classificação fornece uma base sólida para garantir os princípios de segurança da informação, que incluem confidencialidade, integridade e disponibilidade (CIA *Triad*). No entanto, a aplicação prática dessa metodologia, especialmente em arquiteturas complexas, pode se tornar morosa e suscetível a inconsistências quando realizada manualmente.

De acordo com o NIST Cybersecurity Framework (NIST, 2018), a identificação antecipada de riscos é essencial para a gestão eficiente da segurança cibernética, sobretudo em ambientes dinâmicos, como aqueles que utilizam computação em nuvem. Além disso, a norma ISO/IEC 27001 estabelece diretrizes para a implementação de Sistemas de Gestão da Segurança da Informação (SGSI), ressaltando a importância de processos estruturados para avaliação de riscos e adoção de controles adequados. Contudo, tais diretrizes não eliminam o desafio operacional associado ao tempo necessário para execução dessas atividades na prática.

Diante desse cenário, a Inteligência Artificial (IA) destaca-se como uma ferramenta promissora na cibersegurança, especialmente por sua capacidade de automatizar a análise de grandes volumes de dados, identificar padrões e apoiar a tomada de decisão. Aplicada à modelagem de ameaças, a IA pode reduzir significativamente o tempo necessário para identificação de

vulnerabilidades, diminuir a dependência de processos manuais e aumentar a consistência das análises, tornando a mitigação mais ágil e eficaz.

1.1 Objetivo geral

Desenvolver uma ferramenta baseada em Inteligência Artificial para realizar a modelagem de ameaças utilizando a metodologia STRIDE em ambientes AWS, com o objetivo de reduzir o tempo de análise em comparação aos processos manuais tradicionais, mantendo um nível adequado de qualidade e cobertura das ameaças identificadas.

1.2 Objetivos Específicos

Identificar os principais conceitos e princípios da metodologia STRIDE aplicáveis à modelagem de ameaças;

Analisar técnicas de Inteligência Artificial adequadas para aprimorar a detecção e classificação de ameaças;

Definir a arquitetura do sistema com base em serviços e recursos disponíveis na AWS;

Implementar um ambiente em nuvem na AWS para suportar a aplicação e o processamento dos dados;

Desenvolver o sistema de modelagem de ameaças que integre STRIDE, IA e infraestrutura em nuvem;

Validar o desempenho e a eficácia do sistema por meio de testes e simulações de cenários de ameaça;

Documentar os resultados obtidos e propor melhorias para futuras implementações.

1.3. Justificativa

A crescente dependência de aplicações em nuvem e a complexidade das arquiteturas modernas ampliam substancialmente a superfície de ataque e introduzem um desafio central de natureza temporal: a velocidade com que novas ameaças surgem e são exploradas supera a capacidade dos processos tradicionais de segurança em identificá-las e mitigá-las de oportunamente. Em ambientes baseados na AWS, onde aplicações, *Application Programming Interface* (APIs) e serviços são continuamente implantados, modificados e escalados, a modelagem de ameaças realizada de forma manual, inclusive utilizando metodologias consolidadas como o STRIDE, tende a ocorrer de maneira pontual, demandando horas ou dias de esforço especializado. Esse intervalo cria janelas de exposição relevantes entre a introdução

de mudanças arquiteturais e a disponibilidade de um modelo de ameaças atualizado e acionável.

Esse desalinhamento temporal é particularmente crítico quando comparado à velocidade dos ataques modernos. Relatórios de resposta a incidentes demonstram que o comprometimento inicial e a movimentação lateral podem ocorrer em questão de minutos ou poucas horas, conforme evidenciado por análises da CrowdStrike e da Verizon. Em contrapartida, o tempo médio para identificação e contenção de incidentes pode ultrapassar 200 dias, de acordo com o relatório *Cost of a Data Breach* da IBM Security.

Adicionalmente, estudos da Mandiant indicam que atacantes frequentemente permanecem ativos em ambientes comprometidos por períodos prolongados antes de serem detectados. Nesse cenário, observa-se que, mesmo com a adoção de frameworks consolidados como o NIST Cybersecurity Framework e a ISO/IEC 27001, a efetividade prática dos controles é impactada pela latência inerente a processos manuais de análise, documentação e resposta a riscos.

Nesse quadro, a Inteligência Artificial surge como uma abordagem promissora para reduzir drasticamente o tempo necessário para a modelagem de ameaças, permitindo que análises STRIDE sejam geradas ou atualizadas de forma contínua e integrada ao ciclo SDLC. Estudos recentes e ferramentas de automação de *Threat Modeling* indicam que a aplicação de técnicas automatizadas, incluindo o uso de modelos de linguagem, pode reduzir o esforço humano e o tempo de elaboração de modelos de ameaça de horas ou dias para minutos, viabilizando sua execução a cada alteração relevante na infraestrutura ou no código. Essa redução temporal é fundamental para alinhar a modelagem de ameaças à realidade dinâmica da AWS e para minimizar a janela de exposição entre mudanças no ambiente e a implementação de controles de segurança.

Corroborando essa necessidade, a PwC (2025) aponta que a adoção de inteligência artificial e arquiteturas em nuvem ampliou expressivamente a superfície de ataque cibernético em organizações no Brasil e no cenário global, reforçando a urgência de abordagens mais proativas e rápidas. Com isso, justifica-se a investigação e a proposição de um modelo de ameaças estruturado segundo o *framework* STRIDE, apoiado por Inteligência Artificial em ambientes AWS, com foco explícito na redução do tempo de análise, na manutenção da qualidade das ameaças identificadas e no fortalecimento do conceito de *Security by Design* em arquiteturas modernas de nuvem.

1.4. Público-alvo

Este trabalho tem como público-alvo médias e grandes empresas que utilizam infraestrutura em nuvem, especialmente a plataforma AWS, e que necessitam fortalecer sua segurança da informação. Organizações dos setores financeiro, saúde, governo, e-commerce e tecnologia são especialmente relevantes por lidarem com dados sensíveis e serviços críticos, que, portanto, devem mitigar antes que entrem em produção.

Dentro dessas empresas, o estudo se direciona a profissionais de segurança cibernética, como CISOs, analistas de segurança, equipes de *DevOps* e *CloudOps*, além de desenvolvedores que buscam implementar o conceito de *Security by Design*. Consultorias especializadas e startups de cibersegurança também podem se beneficiar da metodologia proposta para *pentests BlackBox*.

A solução visa reduzir o tempo de detecção de ameaças, melhorar a conformidade com normas internacionais, como o NIST Cybersecurity Framework e a ISO/IEC 27001, e aumentar a resiliência de sistemas modernos diante do crescimento das ameaças digitais.

1.5. Estrutura do Trabalho

Este trabalho está organizado da seguinte forma: o Capítulo 2 apresenta os conceitos fundamentais de segurança da informação, incluindo governança, ameaças e controles de segurança. O Capítulo 3 aborda segurança em nuvem na AWS, contemplando arquitetura, superfície de ataque e boas práticas. O Capítulo 4 discute os fundamentos da Inteligência Artificial Generativa aplicada à segurança da informação e os riscos associados ao seu uso.

No Capítulo 5 são apresentados os conceitos de modelagem de ameaças, com foco nos modelos STRIDE e DREAD. O Capítulo 6 descreve a metodologia adotada, o ambiente experimental e as tecnologias utilizadas no desenvolvimento da solução. O Capítulo 7 apresenta a arquitetura da solução proposta e seu fluxo de processamento.

O Capítulo 8 demonstra o funcionamento da aplicação e os outputs gerados durante a execução da modelagem de ameaças. O Capítulo 9 apresenta a análise dos resultados obtidos, incluindo comparações e avaliação de custos da abordagem proposta. Por fim, o Capítulo 10 apresenta as conclusões do trabalho, suas limitações e sugestões para trabalhos futuros.

2. Segurança da Informação

A segurança da informação configura-se como um campo transversal às tecnologias digitais e à governança organizacional, tendo como objetivo a proteção de ativos informacionais contra riscos capazes de comprometer sua confidencialidade, integridade e disponibilidade (STALLINGS; BROWN, 2018). Nessa conjuntura, a crescente digitalização dos processos organizacionais, aliada à adoção intensiva de ambientes em nuvem, tem ampliado de forma relevante a superfície de ataque e a complexidade das ameaças (GARTNER, 2023).

A transformação digital em escala global tem intensificado a complexidade dos desafios relacionados à proteção de dados e sistemas, impulsionada tanto pela evolução tecnológica quanto pela descentralização das infraestruturas digitais. Nesse contexto, evidencia-se a necessidade de abordagens mais estruturadas e dinâmicas para a gestão de riscos em segurança da informação (PRICEWATERHOUSECOOPERS, 2025).

Nesse âmbito, alguns conceitos fundamentais orientam a análise e a tomada de decisão:

- Ativo de informação: qualquer dado, sistema, processo ou recurso cujo valor para a organização justifique sua proteção;
- Ameaça: evento ou agente capaz de explorar vulnerabilidades e causar impacto negativo aos ativos;
- Vulnerabilidade: fraqueza existente em um ativo ou controle que pode ser explorada;
- Risco: resultado da combinação entre a probabilidade de ocorrência de uma ameaça e o impacto associado à sua materialização.

Esses elementos constituem a base para a definição de controles de segurança, priorização de investimentos e elaboração de estratégias de resposta a incidentes.

Adicionalmente, a segurança da informação é tradicionalmente estruturada a partir da tríade CIA (*Confidentiality, Integrity and Availability*), composta pelos seguintes princípios:

- Confidencialidade: garantia de que o acesso às informações ocorre apenas por entidades autorizadas;
- Integridade: assegura que os dados permaneçam completos e não sejam alterados de forma indevida;
- Disponibilidade: garante que informações e serviços estejam acessíveis sempre que necessários.

Contudo, abordagens contemporâneas ampliam esse modelo ao incorporar propriedades adicionais, como autenticidade, responsabilidade (accountability) e resiliência, refletindo a

necessidade de assegurar não apenas a proteção dos dados, mas também a capacidade de auditoria, rastreabilidade e continuidade operacional (WHITMAN; MATTORD, 2021; ISO/IEC 27001, 2022).

Conforme destacado por Pias (2025), o avanço das ameaças cibernéticas e o aumento da sofisticação dos ataques exigem que as organizações adotem medidas de segurança cada vez mais proativas, integradas e orientadas a risco, superando modelos puramente reativos e baseados em controles estáticos.

Na figura 1 demonstra os pilares da segurança da Informação:

Figura 1: Tríade CID



Fonte: Pronnus, 2025.

2.1. Governança, Normas e *Compliance*

A segurança da informação deve estar integrada à governança corporativa. *Frameworks* e normas reconhecidos, como ISO/IEC 27001 e o NIST Cybersecurity Framework, orientam a criação de Sistemas de Gestão de Segurança da Informação (SGSI), processos de gestão de risco e controles técnicos e administrativos. No contexto brasileiro, a conformidade com a Lei nº 13.709/2018 (LGPD) é também um requisito central para a proteção de dados pessoais (Brasil, 2018).

Além disso, práticas modernas de controle e identidade em ambientes de nuvem utilizam o *Identity and Access Management* (IAM) para assegurar o princípio do menor privilégio (IBM Corporation, 2021). De forma complementar, Manepalli (2021) discute a importância de pipelines de segurança integrados (DevSecOps) para garantir que segurança, automação e monitoramento caminhem juntos no ciclo de desenvolvimento. O trabalho em questão integra

essas referências ao propor uma modelagem de ameaças para ambientes em nuvem com base nesses princípios e frameworks.

2.2. Ameaças, vetores e modelagem

As ameaças variam de ataques oportunistas (como malware e phishing) a campanhas direcionadas (Advanced Persistent Threats - APTs), exploração de credenciais e abuso de APIs. Modelos de modelagem de ameaças, como STRIDE, ajudam a classificar e estruturar a análise de riscos, considerando Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service e Elevation of Privilege.

Segundo Yazmyradov e Lee (2024), o uso de técnicas de inteligência artificial pode aprimorar a identificação e priorização de riscos ao automatizar etapa do processo de análise de ameaças. Assim, a prática de modelagem deve ocorrer nas fases iniciais do ciclo *SSDLC*, reduzindo custos e impactos de correções tardias. Este TCC explora a aplicação de STRIDE em conjunto com técnicas automatizadas de IA para melhorar a precisão e eficiência da análise de ameaças.

2.3. Controles e boas práticas

Uma defesa funcional combina controles técnicos, administrativos e físicos (NIST, 2020); algumas práticas recomendadas:

2.3.1. Controles técnicos

Gerenciamento de identidade e acesso (IAM) com princípio do menor privilégio e autenticação multifator (FERRAIOLO; KUHN, 2009);

Criptografia em trânsito e em repouso para dados sensíveis (BARKER; ROGINSKY, 2019);

Segmentação de redes e microsegmentação (especialmente em ambientes *cloud*) (SCARFONE; MELL, 2007);

Monitoramento contínuo, *logging* centralizado e análise de eventos (SIEM/EDR) (KENT; SOUPPAYA, 2006);

Gestão de vulnerabilidades (*scans*, *patching*, SCA para dependências) (MELL; SCARFONE; ROMANOSKY, 2007);

Backup e testes regulares de restauração (SWANSON et al., 2002).

2.3.2. Controles administrativos

Políticas e procedimentos documentados (incluindo classificação de dados) (ISO/IEC 27001, 2022);

Treinamento e conscientização de usuários (WILSON; HASH, 2003);

Gestão de fornecedores/terceiros e avaliações de risco (BOYENS et al., 2015);

Processos de autorização para mudanças (change management) (WINKLER, 2011).

2.3.3 Controles físicos

Controle de acesso a datacenters e dispositivos críticos (STOUFFER et al., 2015);

Proteções ambientais e redundâncias de infraestrutura (SWANSON et al., 2002);

A combinação coerente desses controles reforça o princípio de *defense-in-depth*, no qual múltiplas camadas de proteção são aplicadas de forma complementar para mitigar riscos e reduzir a probabilidade de comprometimento dos ativos informacionais (NSA, 2010).

Entretanto, a efetividade dessas práticas sofre influência direta do ambiente tecnológico no qual são implementadas. Com a crescente adoção de modelos baseados em computação em nuvem, nota-se uma mudança significativa na forma como os controles de segurança são projetados, implementados e operados (MELL; GRANCE, 2011). Diferentemente dos ambientes tradicionais *on-premises*, nos quais a organização detém controle direto sobre toda a infraestrutura, a computação em nuvem introduz um modelo compartilhado de responsabilidades, no qual provedores e clientes dividem a gestão da segurança (AMAZON WEB SERVICES, 2023).

Nesse novo paradigma, aspectos como elasticidade, distribuição geográfica, provisionamento sob demanda e uso intensivo de serviços gerenciados ampliam tanto as capacidades de proteção quanto a complexidade da superfície de ataque (FERNANDES et al., 2014). Consequentemente, práticas tradicionais de segurança precisam ser adaptadas para contemplar novos vetores de risco, como configurações inadequadas de serviços, exposição indevida de dados e falhas na gestão de identidades e acessos (MODI et al., 2013).

Em razão desse cenário, torna-se necessário compreender os fundamentos da computação em nuvem, bem como os mecanismos específicos de segurança associados a esse modelo. Assim, o próximo capítulo aborda os conceitos de computação em nuvem, com ênfase nos serviços da AWS e nas práticas de segurança aplicáveis a esse ambiente.

3. Segurança em Nuvem na AWS: Fundamentos, Arquitetura e Superfície de Ataque

A computação em nuvem caracteriza-se como um modelo de provisão de recursos de tecnologia da informação sob demanda, disponibilizados por meio da internet, permitindo o acesso a serviços como processamento, armazenamento, bancos de dados e aplicações sem a necessidade de infraestrutura física local (MELL; GRANCE, 2011).

Adicionalmente, o modelo de pagamento por uso e a alta disponibilidade dos serviços contribuem para a otimização financeira e continuidade operacional. A capacidade de acesso remoto e a integração com serviços avançados, como inteligência artificial, machine learning e análise de dados em larga escala, ampliam o potencial de inovação, tornando a nuvem um elemento central na transformação digital das organizações.

3.1. Modelo de Responsabilidade Compartilhada da AWS

No contexto da computação em nuvem, a segurança é estruturada a partir do modelo de responsabilidade compartilhada, no qual as atribuições são divididas entre o provedor de serviços e o cliente.

De acordo com a Amazon Web Services (2020), a responsabilidade da AWS está relacionada à segurança da nuvem (*security of the cloud*), abrangendo a proteção da infraestrutura física e lógica que sustenta os serviços, incluindo data centers, hardware, redes e camada de virtualização.

Por outro lado, cabe ao cliente a responsabilidade pela segurança na nuvem (*security in the cloud*), o que inclui a proteção de dados, configuração de serviços, gerenciamento de identidades e acessos (IAM), além da segurança de sistemas operacionais e aplicações implantadas.

Esse modelo implica que falhas de configuração, como permissões excessivas, exposição de serviços ou ausência de criptografia, são de responsabilidade direta do cliente. Conforme reforçado pela AWS (2023), o provedor não acessa os dados dos usuários, sendo incumbência destes garantir a proteção e a conformidade com regulamentações, como a Lei Geral de Proteção de Dados (LGPD).

3.2. Arquitetura de Referência Segura na AWS

A construção de uma arquitetura segura em ambientes da AWS baseia-se na adoção de princípios de isolamento, segmentação e monitoramento contínuo, estruturados em múltiplas camadas de defesa (AMAZON WEB SERVICES, 2023).

Um padrão amplamente adotado é o modelo multi-conta, implementado por meio do AWS Organizations, que permite a separação lógica de ambientes, como produção, homologação e auditoria, além da aplicação centralizada de políticas de governança, como *Service Control Policies* (SCPs) (AMAZON WEB SERVICES, 2022). Essa abordagem reduz o impacto de falhas e limita a propagação de incidentes de segurança (SCARFONE; SOUPPAYA; HOFFMAN, 2011).

Cada conta é tipicamente estruturada em uma ou mais *Virtual Private Clouds* (VPCs), que definem o isolamento de rede. Dentro dessas VPCs, os recursos são distribuídos em múltiplas zonas de disponibilidade (*Availability Zones*), garantindo alta disponibilidade e resiliência (AMAZON WEB SERVICES, 2024).

As arquiteturas seguras seguem o princípio de segmentação em camadas (SCARFONE; MELL, 2007):

- Camada de entrada (*edge*): composta por serviços como Elastic Load Balancer e protegida por mecanismos como AWS *Web Application Firewall* (WAF), responsável por filtrar e distribuir o tráfego externo;
- Camada de aplicação: localizada em sub-redes privadas, onde residem os serviços de *backend*;
- Camada de dados: também isolada, responsável pelo armazenamento seguro de informações críticas.

O tráfego entre essas camadas é controlado por regras de segurança restritivas, utilizando *security groups* e network ACLs, enquanto logs e eventos são centralizados em serviços como AWS CloudTrail e Amazon CloudWatch, permitindo auditoria e detecção de anomalias (KENT; SOUPPAYA, 2006).

Adicionalmente, serviços nativos como AWS GuardDuty, AWS Security Hub e Amazon Inspector são utilizados para monitoramento contínuo, identificação de ameaças e avaliação de vulnerabilidades (AMAZON WEB SERVICES, 2023).

Essa abordagem estruturada, baseada em múltiplas camadas de proteção, implementa o conceito de *defense-in-depth*, no qual a falha de um controle isolado não compromete integralmente o ambiente, contribuindo para uma postura de segurança mais resiliente e robusta (NSA, 2010; NIST, 2020).

possibilidades de exploração por agentes maliciosos, conforme discutido por OWASP (2021) e pela Amazon Web Services (2023).

Entre os principais vetores de ataque, destacam-se:

- Credenciais comprometidas:

O comprometimento de credenciais constitui um dos vetores mais críticos em ambientes AWS.

Chaves de acesso podem ser obtidas por meio de técnicas como *phishing*, reutilização de senhas, vazamentos em repositórios públicos ou exposição em ferramentas colaborativas.

Um exemplo relevante ocorreu com a empresa Animal Jam, em 2020, quando uma chave de acesso AWS foi exposta em um canal interno de comunicação, permitindo que invasores acessassem bases de dados e exfiltrassem milhões de registros (CORFIELD, 2020).

Esse tipo de incidente evidencia a importância de controles como autenticação multifator (MFA), rotação periódica de credenciais e adoção de identidades temporárias (*temporary credentials*), reduzindo o risco associado ao uso indevido de acessos privilegiados.

- Exposição indevida de recursos públicos:

Configurações incorretas de serviços, especialmente em armazenamento e rede, representam uma das causas mais frequentes de incidentes em nuvem. *Buckets* do Amazon S3 configurados como públicos ou regras permissivas em *security groups* podem permitir acesso não autorizado ou até mesmo a manipulação de dados.

No caso da Twilio, em 2020, uma configuração inadequada em um *bucket* S3 permitiu que um agente externo inserisse código malicioso em um *Software Development Kit* (SDK) JavaScript, resultando na distribuição de conteúdo comprometido para usuários finais. Esse cenário demonstra como permissões excessivas podem ser exploradas para ataques de cadeia de suprimentos (*supply chain attacks*).

Outro caso emblemático é o da Capital One, em 2019, no qual uma falha de configuração em um WAF permitiu a exploração de uma vulnerabilidade do tipo SSRF (*Server-Side Request Forgery*), possibilitando o acesso ao serviço de metadados da AWS e a consequente obtenção de credenciais de IAM resultando em vazamento massivo de dados.

- Ambientes e *workloads* vulneráveis:

Instâncias de computação e contêineres desatualizados ou mal configurados representam outro vetor relevante. Imagens comprometidas ou ausência de correções de segurança (*patching*) podem permitir a execução de códigos maliciosos.

Grupos de ameaças como o TeamTNT têm explorado ambientes Docker e Kubernetes expostos para executar atividades ilícitas, como mineração de criptomoedas e movimentação lateral na infraestrutura.

- Exploração de aplicações e APIs:

Aplicações web e APIs expostas na internet também ampliam a superfície de ataque.

Vulnerabilidades como *Structured Query Language (SQL) Injection*, *Cross-Site Scripting* (XSS) e falhas de autenticação podem ser exploradas caso não existam mecanismos adequados de proteção, como WAF, validação de entrada e autenticação robusta.

Além disso, APIs mal configuradas podem permitir acesso indevido a recursos críticos, especialmente quando combinadas com falhas de autorização.

De forma geral, verifica-se que muitos incidentes em ambientes AWS não decorrem de falhas na infraestrutura do provedor, mas sim de erros de configuração e gestão por parte dos usuários, especialmente relacionados a identidade, permissões e exposição de recursos.

Em síntese, casos como os incidentes envolvendo Animal Jam, Twilio e Capital One evidenciam padrões recorrentes de falhas, como credenciais expostas, permissões excessivas e configurações inadequadas, reforçando a necessidade de adoção rigorosa de práticas de segurança, incluindo gestão de identidades, revisão contínua de configurações e monitoramento ativo do ambiente.

3.4. Controles e Boas Práticas Específicas para AWS

A Tabela a seguir sintetiza recomendações típicas em AWS, priorizando controles críticos frente a custo/complexidade de implementação:

Tabela 1: Recomendações de Boas práticas da AWS.

Controle / Prática	Prioridade	Custo/Complexidade
IAM: políticas <i>least privilege</i>	Alta	Baixo/Médio
Autenticação multifator (MFA)	Alta	Baixo
Uso de IAM Roles em vez de chaves estáticas	Alta	Médio
Criptografia (KMS, S3 SSE, TLS)	Alta	Médio
Logging: habilitar CloudTrail e AWS Config	Alta	Médio
Monitoramento: GuardDuty, Security Hub	Alta	Médio
Auditoria: Amazon Inspector	Média	Médio

Controle / Prática	Prioridade	Custo/Complexidade
WAF/WebShield (regras anti-DDoS)	Média	Médio/Alto
Grupos de Segurança restritivos	Alta	Baixo/Médio
VPC Endpoints (AWS PrivateLink)	Média	Médio
Análise de IaC (segurança em CI/CD)	Média	Médio
Patching automatizado (SSM)	Alta	Baixo/Médio
Planejamento de Resposta a Incidentes	Média	Médio

Fonte: AWS Well Architecture, 2025

Cada controle acima reforça a segurança conforme o modelo compartilhado e as melhores práticas da AWS. Por exemplo, políticas de identidade rigorosas e criptografia robusta têm alta prioridade, ao mitigarem riscos diretos de acesso indevido e vazamento de dados. A implementação de WAF ou *Shield*, embora efetiva, pode ter custo/complexidade maior, sendo adotada em segundo plano se necessário. Em todos os casos, recomenda-se alinhar essas medidas a *frameworks* como ISO 27001 e NIST CSF.

Observa-se que a adoção de controles técnicos e práticas consolidadas de segurança, embora essencial, não elimina completamente os desafios associados à identificação contínua de ameaças em ambientes modernos de nuvem. O aumento da complexidade arquitetural, da velocidade de desenvolvimento e da diversidade de serviços utilizados torna o processo de modelagem de ameaças progressivamente mais dependente de automação, análise contextual e capacidade de correlação de informações em larga escala. A Inteligência Artificial surge como uma abordagem promissora para apoiar atividades de identificação, categorização e priorização em massa de dados como será mostrado no próximo capítulo.

4. Inteligência Artificial Generativa e Segurança da Informação: Conceitos, Aplicações e Desafios

A Inteligência Artificial (IA) pode ser definida como o campo da ciência da computação dedicado ao desenvolvimento de sistemas capazes de realizar tarefas que, tradicionalmente, exigiriam inteligência humana, tais como reconhecimento de padrões, tomada de decisão, aprendizado e interpretação de dados (RUSSELL; NORVIG, 2021).

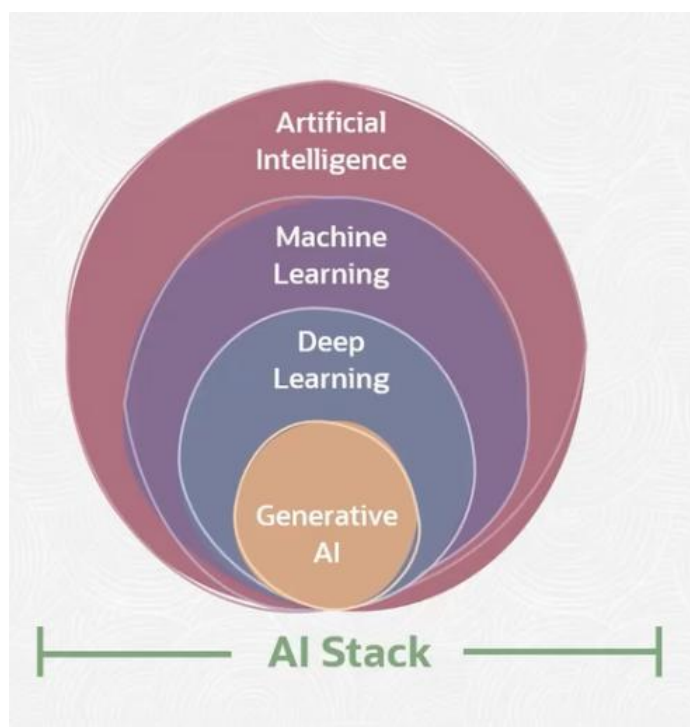
Nas últimas décadas, a IA evoluiu de forma substancial, impulsionada pelo aumento da capacidade computacional, disponibilidade de grandes volumes de dados e avanços em algoritmos de aprendizado (RUSSELL; NORVIG, 2021). Esse progresso possibilitou sua aplicação em diversos domínios, incluindo segurança da informação, análise preditiva, automação de processos e sistemas de recomendação (GOODFELLOW; BENGIO; COURVILLE, 2016).

4.1. Fundamentos de Inteligência Artificial

De forma geral, a Inteligência Artificial pode ser categorizada em diferentes abordagens, destacando-se o *Machine Learning* (ML), o *Deep Learning* (DL) e, mais recentemente, a Inteligência Artificial Generativa (Generative AI).

Na figura 3, é demonstrado visualmente as diferenças e camadas da Inteligência artificial:

Figura 3: Representação conceitual das camadas de IA, ML e *Deep Learning*



Fonte: All Things Open, 2021

O *Machine Learning* consiste em um subconjunto da IA que permite aos sistemas aprenderem padrões a partir de dados, sem a necessidade de programação explícita para cada tarefa. Modelos de ML utilizam técnicas estatísticas para identificar relações e realizar previsões, sendo amplamente aplicados em detecção de anomalias, classificação e análise de comportamento (GOODFELLOW; BENGIO; COURVILLE, 2016).

O *Deep Learning*, por sua vez, é uma subárea do *Machine Learning* baseada em redes neurais artificiais profundas, capazes de processar grandes volumes de dados e extrair características complexas de forma hierárquica. Essa abordagem é especialmente resolutive em tarefas como reconhecimento de imagens, processamento de linguagem natural e análise de padrões complexos, sendo amplamente utilizada em sistemas modernos de IA (LECUN; BENGIO; HINTON, 2015).

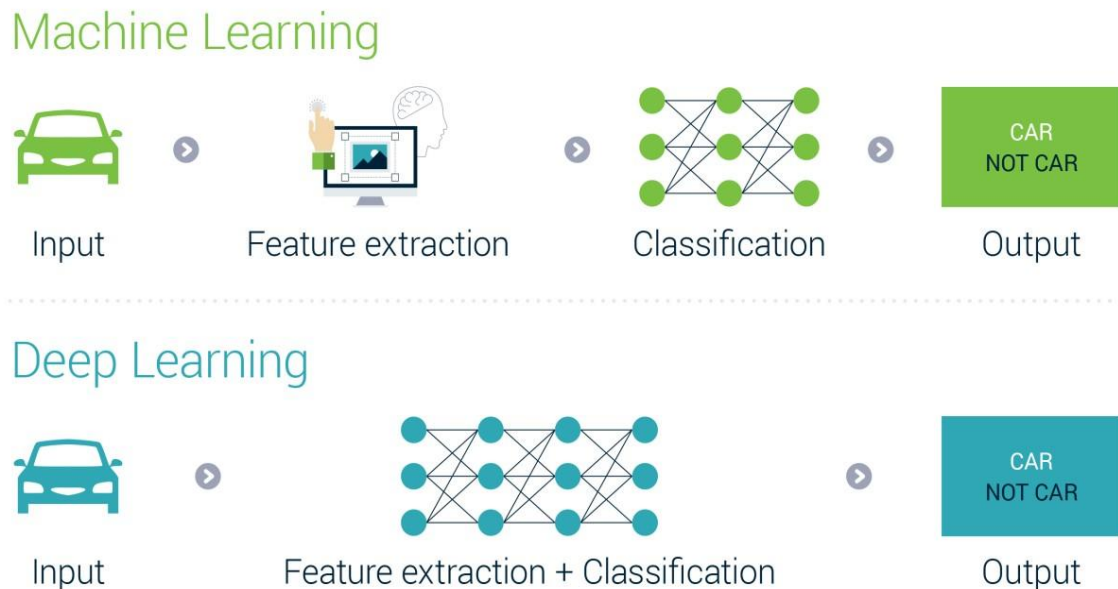
Mais recentemente, destaca-se a IA Generativa, que tem como objetivo a criação de novos conteúdos a partir de dados de treinamento, incluindo textos, imagens, código e outros tipos de informação. Modelos generativos, como os baseados em arquiteturas de transformadores, são capazes de compreender contextos e gerar respostas coerentes, ampliando consideravelmente as possibilidades de aplicação da IA em áreas como automação de análise, suporte à decisão e geração de conhecimento (VASWANI et al., 2017).

No contexto da IA generativa, os *Large Language Models* (LLMs) representam uma classe de modelos de linguagem de grande escala, treinados em vastos corpora textuais e caracterizados por bilhões de parâmetros. Modelos como GPT-4, Claude e PaLM demonstram capacidades emergentes em raciocínio complexo, compreensão contextual profunda e geração de texto de alta qualidade, sendo aplicados em tarefas que vão desde assistência técnica até análise de segurança cibernética (BROWN et al., 2020; OPENAI, 2023). Porém, o custo computacional e os requisitos de infraestrutura associados aos LLMs motivam o desenvolvimento de *Small Language Models* (SLMs), modelos mais compactos com menor número de parâmetros, otimizados para eficiência e implantação em ambientes com recursos limitados (TOUVRON et al., 2023). Os SLMs, como Phi-3, Mistral e Gemma, utilizam técnicas avançadas de destilação de conhecimento, quantização e arquiteturas eficientes para manter desempenho competitivo em tarefas específicas, oferecendo vantagens em termos de latência, custo operacional e privacidade de dados (GUNASEKAR et al., 2023; JIANG et al., 2023). A escolha entre LLMs e SLMs depende do contexto de aplicação, considerando *trade-offs* entre capacidade de generalização, requisitos computacionais e restrições operacionais.

A Figura 4 ilustra as principais diferenças nos processos de treinamento entre *Machine Learning* tradicional e *Deep Learning*, destacando a complexidade das arquiteturas de redes

neurais profundas e os requisitos computacionais distintos de cada abordagem.

Figura 4: Diferença de treinamento de modelos de ML e *Deep Learning*



Fonte: LinkedIn, Gauri Bapat, 2019.

O treinamento de modelos de IA pode ser categorizado em diferentes padrões, cada um adequado a contextos e objetivos específicos. O aprendizado supervisionado (*supervised learning*) constitui a abordagem mais tradicional, na qual o modelo é treinado utilizando um conjunto de dados rotulados, ou seja, exemplos de entrada acompanhados de suas respectivas saídas esperadas (GOODFELLOW; BENGIO; COURVILLE, 2016). Nesse paradigma, o algoritmo aprende a mapear entradas para saídas através da minimização de uma função de perda que quantifica a discrepância entre as previsões do modelo e os rótulos verdadeiros. Aplicações típicas incluem classificação de imagens, reconhecimento de fala e detecção de spam, onde a disponibilidade de dados rotulados permite que o modelo generalize padrões para novos exemplos não vistos durante o treinamento (RUSSELL; NORVIG, 2020). Em contraste, o aprendizado não supervisionado (*unsupervised learning*) opera sobre dados não rotulados, buscando identificar estruturas, padrões ou agrupamentos intrínsecos aos dados sem orientação explícita sobre o resultado desejado (HASTIE; TIBSHIRANI; FRIEDMAN, 2009). Técnicas como *clustering*, redução de dimensionalidade e detecção de anomalias são exemplos desse modelo, frequentemente empregadas em análise exploratória de dados e descoberta de conhecimento (BISHOP, 2006).

Além desses dois paradigmas principais, existem abordagens híbridas e especializadas

que ampliam as capacidades dos sistemas de aprendizado de máquina. O aprendizado por reforço (*reinforcement learning*) baseia-se na interação de um agente com um ambiente, no qual o agente aprende a tomar decisões mediante tentativa e erro, recebendo recompensas ou penalidades com base nas ações executadas (SUTTON; BARTO, 2018). Esse referencial tem sido fundamental para avanços em jogos estratégicos, robótica e sistemas de recomendação adaptativos. O aprendizado semi-supervisionado (*semi-supervised learning*) combina pequenas quantidades de dados rotulados com grandes volumes de dados não rotulados, sendo particularmente útil em cenários onde a rotulação manual é custosa ou impraticável (ZHU; GOLDBERG, 2009). Adicionalmente, o aprendizado por transferência (*transfer learning*) permite que conhecimento adquirido em uma tarefa seja reutilizado para melhorar o desempenho em tarefas relacionadas, reduzindo de maneira significativa a necessidade de dados e recursos computacionais (PAN; YANG, 2010). No contexto de modelos de linguagem de grande escala, como os utilizados em aplicações de processamento de linguagem natural, técnicas de *fine-tuning* e *few-shot learning* têm se mostrado eficazes para adaptar modelos pré-treinados a domínios específicos com mínima supervisão adicional (BROWN et al., 2020; DEVLIN et al., 2019).

4.2. Inteligência Artificial na Segurança da Informação

A aplicação de IA na segurança da informação tem se consolidado como um dos principais vetores de evolução na proteção de ambientes digitais, especialmente diante do aumento do volume de dados, da complexidade das arquiteturas e da sofisticação das ameaças cibernéticas (SOMMER; PAXSON, 2010; BUCZAK; GUVEN, 2016). Nesse contexto, técnicas de IA permitem automatizar processos, identificar padrões anômalos e apoiar a tomada de decisão em tempo quase real (CHANDOLA; BANERJEE; KUMAR, 2009).

Um dos principais usos da IA em segurança da informação está na detecção de ameaças e anomalias. Modelos baseados em *Machine Learning* são capazes de analisar grandes volumes de logs e eventos de rede, identificando comportamentos fora do padrão esperado. Essa abordagem é particularmente efetiva na detecção de ataques desconhecidos (*zero-day*) e atividades maliciosas que não seguem assinaturas previamente catalogadas (SOMMER; PAXSON, 2010).

Outro campo relevante é a análise de logs e correlação de eventos, tradicionalmente realizada por sistemas SIEM (*Security Information and Event Management*). Com o uso de IA, torna-se possível aprimorar a correlação entre eventos aparentemente isolados, reduzindo falsos positivos e aumentando a precisão na identificação de incidentes. Segundo a ENISA (2023), o uso de técnicas avançadas de análise comportamental tem contribuído significativamente para a

melhoria da visibilidade e resposta a incidentes em ambientes complexos.

A IA também desempenha um papel importante na resposta a incidentes, por meio da automação de ações corretivas e contenção de ameaças. Soluções modernas de segurança utilizam *Security Orchestration, Automation and Response* (SOAR) integradas com algoritmos de IA para executar respostas automáticas, como isolamento de sistemas comprometidos, bloqueio de acessos suspeitos e aplicação de políticas de mitigação, reduzindo o tempo de reação a incidentes (SHARMA et al., 2020).

Além disso, destaca-se a automação de processos de segurança, que permite reduzir a dependência de análises manuais e aumentar a escalabilidade das operações. A IA pode ser utilizada para priorizar vulnerabilidades, classificar riscos e apoiar a tomada de decisão em ambientes com grande volume de ativos e eventos. Esse aspecto é especialmente relevante em ambientes de computação em nuvem, nos quais a elasticidade e a dinamicidade dos recursos exigem monitoramento contínuo e adaptativo.

No contexto específico da segurança em nuvem, a aplicação de IA contribui para a análise de configurações, identificação de exposições indevidas e detecção de comportamentos suspeitos relacionados a identidades e acessos (MODI et al., 2013). Ferramentas baseadas em IA são capazes de analisar padrões de uso de credenciais, detectar acessos anômalos e identificar possíveis comprometimentos, reforçando a segurança em ambientes distribuídos (SINGH; SHRIVASTAVA, 2012).

4.3. Riscos do uso de Inteligência Artificial em Segurança da Informação

Apesar dos benefícios proporcionados pela aplicação de IA na segurança da informação, sua adoção introduz novos riscos que devem ser considerados no processo de governança e gestão de segurança (PAPERNOT et al., 2016). Esses riscos estão relacionados tanto às limitações intrínsecas dos modelos quanto às possibilidades de exploração maliciosa de seus mecanismos (BIGGIO; ROLI, 2018).

Um dos principais riscos associados ao uso de IA, especialmente em modelos generativos, é o *prompt injection*. Esse tipo de ataque consiste na manipulação das entradas fornecidas ao modelo com o objetivo de induzi-lo a gerar respostas indevidas, ignorar instruções de segurança ou revelar informações sensíveis. Em contextos de segurança, isso pode comprometer a confiabilidade das análises realizadas e levar à geração de resultados incorretos ou potencialmente perigosos (NIST, 2018).

A alucinação de modelos também representa uma limitação significativa. Esse fenômeno ocorre quando a IA gera respostas plausíveis, porém incorretas ou não fundamentadas em dados

reais (JI et al., 2023). Em cenários de segurança da informação, decisões baseadas em informações imprecisas podem resultar em classificações errôneas de riscos, falhas na identificação de ameaças ou adoção de controles inadequados (ZHANG et al., 2023).

Outro aspecto relevante refere-se à adoção do princípio de *human-in-the-loop*, no qual a participação humana é incorporada de forma contínua ao processo automatizado (MOSQUEIRA-REY et al., 2023). Embora a automação proporcione ganhos significativos de eficiência, a ausência de validação humana em etapas críticas pode levar à propagação de erros, interpretações inadequadas e decisões inconsistentes (SHNEIDERMAN, 2020). Nesse contexto, a presença do usuário como elemento de validação e ajuste dos resultados gerados pela IA torna-se essencial para garantir maior confiabilidade, permitindo a identificação de falhas, correções de inconsistências e refinamento contínuo do processo de modelagem de ameaças (AMERSHI et al., 2019).

A crescente complexidade dos ambientes digitais, especialmente em arquiteturas distribuídas e em nuvem, exige métodos formais que permitam compreender como ameaças podem explorar vulnerabilidades e impactar ativos críticos.

É considerando este quadro que se destaca a modelagem de ameaças (*Threat Modeling*), uma abordagem que permite identificar, categorizar e priorizar riscos de segurança desde as fases iniciais do desenvolvimento de sistemas. Modelos como STRIDE fornecem estruturas consolidadas para análise de ameaças e avaliação de riscos, contribuindo para uma visão mais sistemática e proativa da segurança.

Assim, após a compreensão dos fundamentos de segurança da informação, computação em nuvem e Inteligência Artificial, torna-se necessário explorar os conceitos e metodologias de modelagem de ameaças, que constituem a base analítica para a identificação e mitigação de riscos no contexto deste trabalho.

5. Modelagem de Ameaças: Identificação, Classificação e Avaliação com STRIDE e DREAD

A modelagem de ameaças (*Threat Modeling*) consiste em um processo estruturado de identificação, análise e mitigação de riscos de segurança em sistemas de informação. Diferentemente de abordagens reativas, que atuam após a ocorrência de incidentes, a modelagem de ameaças adota uma postura proativa, buscando antecipar possíveis cenários de ataque e permitindo que vulnerabilidades sejam identificadas e tratadas ainda nas fases iniciais do ciclo de desenvolvimento (SHOSTACK, 2014, p.3-7).

De acordo com a NIST (2018), práticas estruturadas de identificação e avaliação de riscos são fundamentais para a implementação de programas eficazes de segurança da informação. Nesse sentido, a modelagem de ameaças atua como mecanismo essencial para apoiar a gestão de riscos, permitindo a identificação de ativos críticos, vetores de ataque e possíveis impactos associados (STONEBURNER; GOGUEN; FERINGA, 2002). Esse enfoque permite reduzir custos de correção, minimizar impactos operacionais e aumentar a resiliência dos sistemas (OWASP, 2021).

A modelagem de ameaças contribui para a integração da segurança ao longo do ciclo de vida de desenvolvimento de software (*Secure Software Development Life Cycle - SSDLC*), promovendo uma abordagem conhecida como *security by design* (MCGRAW, 2006). Ao incorporar a análise de ameaças desde as fases iniciais de concepção, as organizações conseguem reduzir a dependência de correções tardias e melhorar a qualidade geral das soluções desenvolvidas (HOWARD; LIPNER, 2006).

A modelagem de ameaças baseia-se na identificação e análise de elementos estruturais que compõem um sistema, permitindo compreender como diferentes componentes interagem e onde possíveis vulnerabilidades podem ser exploradas. Esses elementos formam a base para a identificação sistemática de ameaças e são essenciais para a aplicação de metodologias como STRIDE e DREAD (SHOSTACK, 2014, p. 21-25).

Os ativos representam todos os recursos que possuem valor para a organização e que, portanto, devem ser protegidos, incluindo dados sensíveis, sistemas, serviços, infraestrutura e credenciais de acesso. A correta identificação dos ativos é um passo crítico, pois orienta toda a análise subsequente de riscos. Em ambientes de computação em nuvem, ativos podem incluir *buckets* de armazenamento, bancos de dados gerenciados, APIs expostas e identidades associadas a serviços (OWASP, 2021).

Os atores correspondem às entidades que interagem com o sistema, podendo ser usuários legítimos, administradores, serviços automatizados ou agentes externos, incluindo possíveis

atacantes (SHOSTACK, 2014). A distinção entre atores confiáveis e não confiáveis é fundamental, uma vez que diferentes perfis de acesso e comportamento podem representar riscos distintos (HOWARD; LIPNER, 2006).

As fronteiras de confiança (*trust boundaries*) delimitam pontos onde há mudança no nível de confiança entre componentes do sistema, indicando locais onde dados transitam entre domínios com diferentes níveis de controle e segurança. Segundo SHOSTACK (2014, p. 44-47), a identificação dessas fronteiras é essencial, pois é nesses pontos que frequentemente ocorrem explorações de vulnerabilidades.

Os fluxos de dados representam o caminho percorrido pelas informações dentro do sistema, incluindo entrada, processamento, armazenamento e saída. A análise desses fluxos permite identificar como os dados são manipulados e onde podem ocorrer exposições, interceptações ou alterações indevidas (DEMARCO, 1979). Essa representação é frequentemente realizada por meio de DFD, que auxiliam na visualização das interações entre componentes (SHOSTACK, 2014).

A superfície de ataque corresponde ao conjunto de todos os pontos de entrada e interação que podem ser explorados por um atacante (MANADHATA; WING, 2011), incluindo interfaces externas, APIs, portas de rede, credenciais e endpoints expostos. Em ambientes de nuvem, a superfície de ataque tende a ser ampliada devido à natureza distribuída dos sistemas, à exposição de serviços via internet e à configuração dinâmica dos recursos (FERNANDES et al., 2014).

Além desses elementos, é importante considerar o contexto operacional e arquitetural do sistema, incluindo dependências externas, integrações com terceiros e características específicas do ambiente, como a utilização de serviços gerenciados em nuvem (SUBASHINI; KAVITHA, 2011). A compreensão integrada desses elementos permite estruturar a análise de ameaças de forma sistemática, garantindo que aspectos críticos não sejam negligenciados e que a modelagem deixe de ser uma atividade intuitiva para se tornar um processo orientado, replicável e alinhado às melhores práticas de segurança da informação.

5.1. Modelo STRIDE para Identificação de Ameaças

O modelo STRIDE é uma metodologia amplamente utilizada na modelagem de ameaças, desenvolvida pela Microsoft, com o objetivo de classificar e identificar ameaças de segurança de forma sistemática (SHOSTACK, 2014, p. 52-80). O acrônimo STRIDE representa seis categorias de ameaças: *Spoofing*, *Tampering*, *Repudiation*, *Information Disclosure*, *Denial of Service* e *Elevation of Privilege*.

A principal vantagem do modelo STRIDE está na sua capacidade de estruturar a análise de ameaças de forma organizada, permitindo que diferentes tipos de riscos sejam avaliados com base em características específicas do sistema (HOWARD; LIPNER, 2006). Essa abordagem é frequentemente aplicada em conjunto com Diagramas de Fluxo de Dados (DFD), nos quais cada elemento do sistema é analisado sob a perspectiva das possíveis ameaças associadas (DEMARCO, 1979; SHOSTACK, 2014).

A categoria *Spoofing* (Falsificação de identidade) refere-se à capacidade de um atacante se passar por uma entidade legítima, como um usuário ou serviço (HOWARD; LIPNER, 2006). Esse tipo de ameaça está diretamente relacionado à autenticação e à gestão de identidades. Em ambientes de nuvem, pode ocorrer, por exemplo, por meio do uso indevido de credenciais comprometidas ou tokens de acesso (FERNANDES et al., 2014).

A categoria *Tampering* (Violação de integridade) envolve a modificação não autorizada de dados, seja em trânsito ou em repouso (SHOSTACK, 2014). Esse tipo de ameaça pode comprometer a integridade das informações e impactar diretamente a confiabilidade dos sistemas. Exemplos incluem alteração de dados em bancos de dados ou manipulação de mensagens em comunicação entre serviços (UZUNOV; FERNANDEZ; FALKNER, 2012).

A *Repudiation* (Repúdio) está relacionada à capacidade de uma entidade negar a realização de determinada ação (HOWARD; LIPNER, 2006). Esse risco ocorre quando não há mecanismos adequados de auditoria e rastreabilidade. A ausência de logs confiáveis e assinaturas digitais pode dificultar a identificação de responsáveis por ações críticas dentro do sistema (STONEBURNER; GOGUEN; FERLINGA, 2002).

A categoria *Information Disclosure* (Divulgação de informação) refere-se ao acesso não autorizado a dados sensíveis (SHOSTACK, 2014). Esse tipo de ameaça compromete a confidencialidade da informação e pode ocorrer por falhas de controle de acesso, exposição indevida de serviços ou ausência de criptografia adequada (FERNANDES et al., 2014).

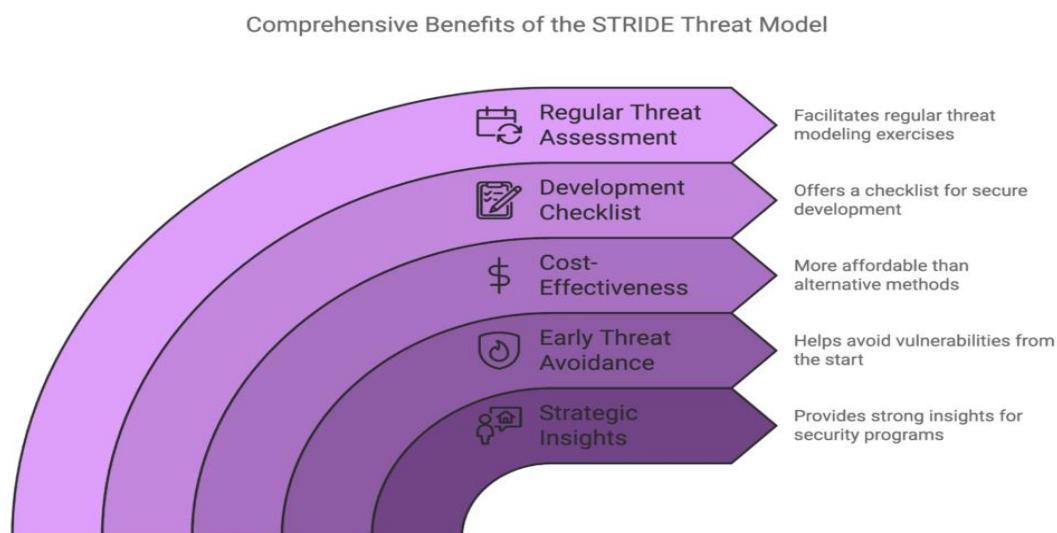
O *Denial of Service* (DoS) consiste na interrupção ou degradação da disponibilidade de serviços, impedindo que usuários legítimos acessem recursos (HOWARD; LIPNER, 2006). Em ambientes de nuvem, ataques desse tipo podem explorar a elasticidade dos sistemas, causando consumo excessivo de recursos e impactando a continuidade operacional (SUBASHINI; KAVITHA, 2011).

Por fim, a categoria *Elevation of Privilege* (Elevação de privilégio) ocorre quando um atacante obtém permissões superiores às originalmente concedidas, permitindo acesso a funcionalidades restritas (SHOSTACK, 2014). Esse tipo de ameaça está frequentemente associado a falhas de autorização e configurações inadequadas de permissões (FERRAILOLO;

KUHN, 2009).

A figura 5 apresenta os principais benefícios do modelo STRIDE na modelagem de ameaças, destacando sua contribuição para a identificação proativa de riscos, suporte ao desenvolvimento seguro e eficiência na gestão de segurança.

Figura 5: Benefícios de uma modelagem de ameaças seguindo o STRIDE



Fonte: practical-devsecops, 2026

Dessa forma, o STRIDE se consolida como uma ferramenta essencial na modelagem de ameaças, permitindo a identificação estruturada de riscos (SHOSTACK, 2014) e servindo como base para a aplicação de métodos complementares de avaliação, como o modelo DREAD, abordado na sequência (HOWARD; LIPNER, 2006).

5.2. Modelo DREAD para Avaliação de Riscos

Após a identificação das ameaças por meio de metodologias como o STRIDE, torna-se necessário avaliar e priorizar os riscos associados a cada uma delas (SHOSTACK, 2014). À luz deste cenário, o modelo DREAD se apresenta como uma abordagem estruturada para mensuração de risco, permitindo classificar ameaças com base em critérios quantitativos e qualitativos (SHOSTACK, 2014, p. 216).

O modelo DREAD é um acrônimo composto por cinco dimensões de avaliação: *Damage*, *Reproducibility*, *Exploitability*, *Affected Users* e *Discoverability* (HOWARD; LEBLANC, 2003). Cada uma dessas dimensões contribui para a análise do impacto e da probabilidade de exploração de uma ameaça, auxiliando na priorização de ações de mitigação.

A dimensão *Damage* (Dano) refere-se ao impacto potencial que a exploração de uma

vulnerabilidade pode causar ao sistema ou à organização. Esse impacto pode incluir perda de dados, interrupção de serviços, prejuízos financeiros ou danos à reputação (HOWARD; LEBLANC, 2003).

A *Reproducibility* (Reprodutibilidade) avalia a facilidade com que um ataque pode ser repetido. Ameaças que podem ser exploradas de forma consistente e repetitiva representam maior risco, uma vez que aumentam a probabilidade de ocorrência de incidentes (HOWARD; LEBLANC, 2003).

A dimensão *Exploitability* (Explorabilidade) está relacionada ao nível de esforço necessário para explorar a vulnerabilidade. Ataques que exigem baixo conhecimento técnico ou ferramentas amplamente disponíveis tendem a apresentar maior criticidade (HOWARD; LEBLANC, 2003).

O critério *Affected Users* (Usuários afetados) considera a quantidade de usuários ou sistemas impactados pela exploração da ameaça. Quanto maior for o número de entidades afetadas, maior o impacto potencial do incidente (HOWARD; LEBLANC, 2003).

Por fim, a *Discoverability* (Descoberta) refere-se à facilidade com que a vulnerabilidade pode ser identificada por um atacante. Vulnerabilidades facilmente detectáveis, seja por análise automatizada ou inspeção manual, representam maior risco (HOWARD; LEBLANC, 2003).

Cada um desses critérios pode ser avaliado por meio de uma escala numérica (por exemplo, de 1 a 10), permitindo a obtenção de uma pontuação final que representa o nível de risco associado à ameaça (SHOSTACK, 2014). Essa pontuação pode ser calculada por meio da média dos valores atribuídos a cada dimensão, conforme a seguinte expressão:

$$DREAD = (D+R+E+A+D)/5$$

Entretanto, o modelo DREAD apresenta algumas limitações. A atribuição de valores para cada critério pode ser subjetiva, variando conforme a experiência dos analistas e o contexto organizacional (HOWARD; LIPNER, 2006). Além disso, o modelo pode não capturar completamente aspectos dinâmicos de ambientes modernos, como mudanças rápidas em arquiteturas de nuvem e evolução constante das ameaças (MEAD; STEHNEY, 2005).

Apesar dessas limitações, o DREAD continua sendo uma ferramenta útil para a avaliação estruturada de riscos, especialmente quando utilizado em conjunto com metodologias de identificação de ameaças, como o STRIDE (SHOSTACK, 2014). A combinação dessas abordagens permite uma análise mais completa, abrangendo tanto a identificação quanto a priorização de riscos.

5.3. Diagramas de Fluxo de Dados (DFD)

Os Diagramas de Fluxo de Dados (*Data Flow Diagrams - DFD*) constituem uma ferramenta fundamental na modelagem de sistemas, sendo amplamente utilizados na modelagem de ameaças para representar, de forma visual e estruturada, como os dados circulam entre diferentes componentes de um sistema (SHOSTACK, 2014, p. 44-47).

O principal objetivo de um DFD é fornecer uma visão clara das interações entre processos, entidades externas e repositórios de dados, permitindo identificar pontos de entrada, transformação e armazenamento de informações (DEMARCO, 1979). Essa representação facilita a compreensão da arquitetura do sistema e auxilia na identificação de possíveis pontos de vulnerabilidade (YOURDON; CONSTANTINE, 1979). Um DFD é composto por quatro elementos principais:

- **Processo (*Process*):** representa uma atividade ou operação que transforma dados de entrada em dados de saída. Em um sistema, processos podem corresponder a funcionalidades da aplicação, serviços ou componentes que realizam tratamento de informações.
- **Entidade Externa (*External Entity*):** corresponde a qualquer elemento externo ao sistema que interage com ele, como usuários, sistemas terceiros ou serviços externos. Essas entidades são importantes na análise de ameaças, pois frequentemente representam pontos de entrada para possíveis ataques.
- **Armazenamento de Dados (*Data Store*):** representa locais onde os dados são armazenados, como bancos de dados, arquivos ou serviços de armazenamento em nuvem. Esses elementos são críticos, pois concentram informações sensíveis que devem ser protegidas.
- **Fluxo de Dados (*Data Flow*):** indica o movimento de dados entre os elementos do sistema, representando como as informações são transferidas entre processos, entidades externas e armazenamentos.

No contexto da modelagem de ameaças, o DFD desempenha um papel central ao servir como base para a aplicação de metodologias como o STRIDE. Cada elemento do diagrama pode ser analisado sob a perspectiva das categorias de ameaça, permitindo uma avaliação sistemática dos riscos associados (KOHNFELDER; GARG, 1999). Por exemplo, processos podem ser avaliados quanto a riscos de elevação de privilégio, fluxos de dados quanto à possibilidade de interceptação ou alteração, e armazenamentos quanto à exposição indevida de informações.

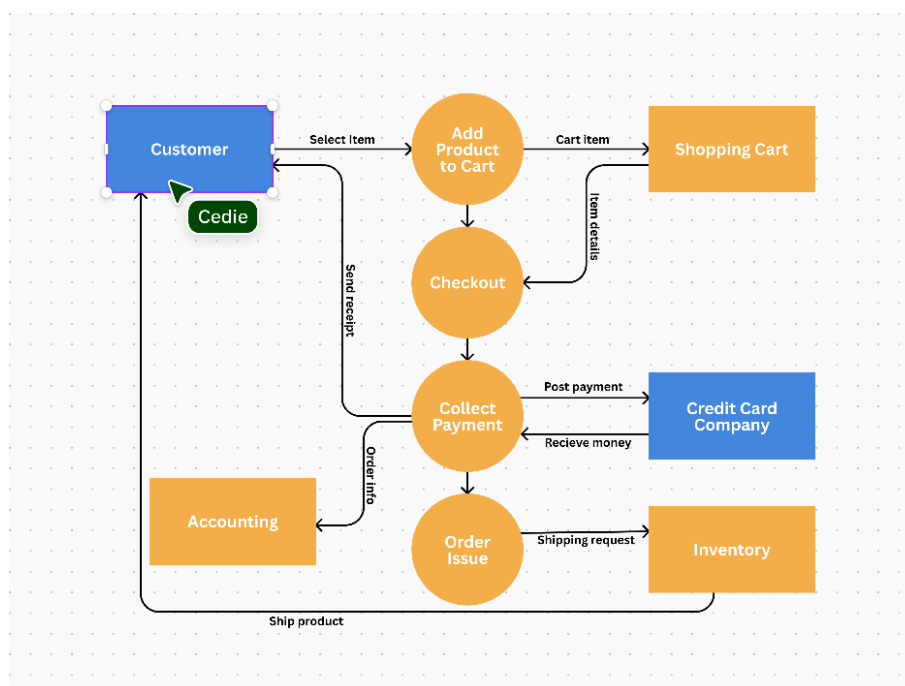
A utilização de DFDs contribui significativamente para a organização e padronização da análise de segurança, reduzindo a probabilidade de omissão de ameaças relevantes (UZUNOV; FERNANDEZ; FALKNER, 2012). Além disso, facilita a comunicação entre equipes técnicas e

não técnicas, permitindo uma compreensão compartilhada da arquitetura e dos riscos envolvidos.

No contexto de ambientes de computação em nuvem, a importância dos DFDs torna-se ainda mais evidente, uma vez que arquiteturas distribuídas e baseadas em serviços aumentam a complexidade dos fluxos de dados e das interações entre componentes (FERNANDES et al., 2014). A representação visual proporcionada pelos DFDs auxilia na identificação de pontos críticos, como APIs expostas, integrações com serviços externos e movimentação de dados entre diferentes camadas da arquitetura.

Na figura 6, temos um exemplo de um Diagrama de fluxo de dados (DFD):

Figura 6: Representação de um DFD



Fonte: Canva, 2025.

Desse modo, os Diagramas de Fluxo de Dados constituem uma ferramenta essencial na modelagem de ameaças, permitindo uma análise estruturada e sistemática da superfície de ataque (DEMARCO, 1979; SHOSTACK, 2014). Sua utilização é fundamental para a aplicação eficaz do modelo STRIDE, fornecendo a base necessária para a identificação e categorização de ameaças em sistemas complexos (MYAGMAR; LEE; YURCIK, 2005).

5.4. Limitações e Desafios da Modelagem de Ameaças

Apesar de sua relevância como prática proativa de segurança, a modelagem de ameaças apresenta limitações que impactam sua efetividade, especialmente em ambientes complexos e dinâmicos, como a computação em nuvem (TORR, 2005). Esses desafios estão relacionados, principalmente, à dependência de fatores humanos, à subjetividade da análise e às dificuldades de escalabilidade do processo (SHOSTACK, 2014).

Um dos principais desafios é a dependência do conhecimento humano. A qualidade da modelagem de ameaças está diretamente associada à experiência e ao nível técnico dos profissionais envolvidos. Analistas com conhecimento limitado sobre arquiteturas, vetores de ataque ou padrões de segurança podem deixar de identificar ameaças relevantes, comprometendo a abrangência da análise (SHOSTACK, 2014, p. 293-315). Esse fator torna o processo suscetível a lacunas, especialmente em equipes com menor maturidade em segurança.

A dificuldade de escala também representa uma limitação significativa. Em ambientes modernos, caracterizados por arquiteturas distribuídas, microserviços e alta dinamicidade, como ocorre em plataformas de computação em nuvem, o número de componentes, interações e fluxos de dados cresce exponencialmente (NEWMAN, 2015). Nesse cenário, a realização manual da modelagem de ameaças torna-se onerosa, demorada e, muitas vezes, impraticável em larga escala (BERGER et al., 2016).

Além disso, destaca-se a necessidade de atualização contínua. Sistemas e arquiteturas estão em constante evolução, seja por mudanças de negócio, atualizações tecnológicas ou adoção de novos serviços. Consequentemente, a modelagem de ameaças deve ser revisitada regularmente para refletir essas alterações. A falta de atualização pode tornar a análise obsoleta, deixando de considerar novos vetores de ataque ou mudanças na superfície de exposição (SHOSTACK, 2014, p. 385-406).

Outro desafio relevante está relacionado à integração da modelagem de ameaças aos processos organizacionais (SHOSTACK, 2014). Em muitos casos, essa prática ainda é tratada como uma atividade pontual, e não como parte contínua do ciclo de desenvolvimento seguro. Essa abordagem limita seu potencial, reduzindo sua efetividade na prevenção de riscos.

Diante dessas limitações, observa-se a necessidade de evolução das abordagens tradicionais de modelagem de ameaças, incorporando mecanismos que permitam maior automação, padronização e escalabilidade do processo (XIONG; LAGERSTRÖM, 2019). Nesse contexto, o uso de tecnologias como Inteligência Artificial surge como uma alternativa promissora para apoiar a identificação e análise de ameaças, reduzindo a dependência exclusiva de análises manuais (SION et al., 2020).

Sob esta perspectiva, torna-se necessário adotar métodos estruturados que não somente organizem a identificação e avaliação de ameaças, mas também permitam sua aplicação prática em ambientes reais, considerando suas particularidades arquiteturais e operacionais. Dessa forma, a utilização de técnicas sistemáticas, aliadas a ferramentas de apoio e automação, possibilita superar limitações relacionadas à escalabilidade, subjetividade e dependência exclusiva de análises manuais (SCANDARIATO et al., 2015).

Diante disso, o presente trabalho adota uma abordagem metodológica baseada na aplicação dos modelos STRIDE e DREAD em um ambiente de computação em nuvem, com o objetivo de estruturar a identificação, classificação e análise de ameaças. Essa abordagem será detalhada no capítulo a seguir, no qual são apresentados os procedimentos, ferramentas e etapas utilizadas para a condução do estudo.

6. Metodologia

Este trabalho adota uma abordagem experimental e aplicada, com o objetivo de avaliar o uso de técnicas de Inteligência Artificial Generativa (GenAI) no apoio à modelagem de ameaças, utilizando a metodologia STRIDE em um ambiente de computação em nuvem. A pesquisa foi conduzida por meio da implementação e análise de um protótipo funcional, utilizado como instrumento para execução dos experimentos e observação dos resultados.

6.1. Tipo de pesquisa

A pesquisa caracteriza-se como aplicada, pois busca solucionar um problema prático relacionado à segurança da informação em ambientes de nuvem, e experimental, uma vez que envolve a construção e avaliação de um sistema para observação de resultados em cenário controlado.

Quanto à abordagem, trata-se de uma pesquisa qualitativa e exploratória, baseada na análise técnica das ameaças identificadas e das recomendações geradas pela Inteligência Artificial.

6.2. Ambiente experimental

O ambiente experimental foi implementado em infraestrutura de computação em nuvem, selecionada por sua compatibilidade com serviços de Inteligência Artificial Generativa. O protótipo desenvolvido foi utilizado como base para execução dos cenários de teste, permitindo a simulação de processos de modelagem de ameaças em contexto realista.

6.3. Utilização da Inteligência Artificial Generativa

A modelagem de ameaças foi apoiada por modelos de Inteligência Artificial Generativa, utilizados para analisar descrições arquiteturais e DFD, gerando automaticamente listas de ameaças classificadas segundo a metodologia STRIDE (*Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service e Elevation of Privilege*).

Para aprimorar a qualidade das respostas, foi empregada a técnica de *Few-Shot Prompting*, na qual exemplos previamente estruturados de arquiteturas e seus respectivos DFDs são fornecidos ao modelo, com o objetivo de melhorar a consistência e contextualização das inferências realizadas. Além disso, pelo uso de LLMs via AWS Bedrock, pode também se considerar uma abordagem do tipo *transfer learning*.

6.4. Processo de modelagem de ameaças

O processo metodológico adotado neste trabalho segue as seguintes etapas:

- Definição da arquitetura do sistema em nuvem e identificação dos principais ativos;
- Representação da arquitetura por meio de DFD;
- Processamento por meio do modelo de IA generativa;
- Geração automática de ameaças categorizadas segundo STRIDE;
- Análise das ameaças geradas e associação a possíveis controles de segurança;
- Avaliação qualitativa da coerência, relevância e utilidade das ameaças identificadas.

Esse processo permite comparar a modelagem tradicional, realizada manualmente, com a modelagem assistida por Inteligência Artificial, considerando aspectos como eficiência, cobertura e padronização dos resultados.

6.5. Execução do experimento

A execução do experimento consistiu na utilização do protótipo desenvolvido para simular cenários de modelagem de ameaças em ambientes de nuvem. Foram definidos cenários representativos, nos quais descrições arquiteturais foram fornecidas ao sistema, permitindo a geração automática de ameaças e sua posterior análise.

A validação da solução proposta foi realizada com base em dois critérios principais: desempenho e qualidade. No que se refere ao desempenho, foi mensurado o tempo necessário para execução da modelagem de ameaças em diversos cenários reais de simulações compartilhadas na internet e devidamente referenciadas na tabela 2 abaixo e em Referencias, comparando-se a abordagem tradicional manual com a abordagem assistida por Inteligência Artificial. Em relação à qualidade, foi conduzida uma análise comparativa entre os resultados gerados pela IA considerando métricas como cobertura de ameaças, taxa de falsos positivos e aderência à metodologia STRIDE. Constata-se, porém, que a literatura carece de métricas padronizadas de avaliação, especialmente no que se refere à taxa de falsos positivos, uma vez que a modelagem de ameaças é predominantemente qualitativa e dependente de contexto.

Essa abordagem permite avaliar não somente o ganho de eficiência operacional, mas também a confiabilidade dos resultados gerados, garantindo que a redução de tempo não comprometa a efetividade da análise de segurança.

Foram testados 20 cenários, cujo tempo de cada um foi medido com cronômetro do

Windows e a qualidade, ou seja, primariamente falsos positivos, revisada manualmente.

6.6. Ambiente Tecnológico e Ferramentas Utilizadas

O desenvolvimento deste protótipo proposto neste trabalho demandou a utilização de um conjunto integrado de tecnologias, abrangendo linguagens de programação, bibliotecas especializadas e *frameworks*. A seleção dessas tecnologias foi orientada por critérios de escalabilidade, facilidade de integração e uso e suporte para aplicações baseadas em IA.

6.6.1. Back-end

O back-end da aplicação foi desenvolvido utilizando Python 3.12 como linguagem principal, escolhida por sua ampla adoção em projetos de inteligência artificial e pela robustez de seu ecossistema de bibliotecas. A infraestrutura como código foi implementada utilizando o *AWS Cloud Development Kit* (CDK) versão 2.157.0, que permite definir recursos de nuvem através de código Python, facilitando a manutenção e versionamento da infraestrutura (AWS, 2024).

6.6.1.1. Frameworks

Para o desenvolvimento das funcionalidades principais, foram utilizadas as seguintes bibliotecas:

a) Boto3 (versão 1.35.16): SDK oficial da AWS para Python, responsável pela comunicação com os serviços da AWS, incluindo Amazon Bedrock, Amazon S3 e Amazon DynamoDB (AMAZON WEB SERVICES, 2023);

b) Pydantic (versão 2.9.1): biblioteca para validação de dados e gerenciamento de configurações através de type hints do Python, garantindo a integridade dos dados manipulados pela aplicação (PYDANTIC, 2024);

c) PynamoDB (versão 6.0.1): ORM (Object-Relational Mapping) para Amazon DynamoDB que simplifica as operações de banco de dados através de uma interface pythônica (PYNAMODB, 2024);

d) AWS Lambda Powertools (versão 2.43.1): conjunto de utilitários para desenvolvimento de funções Lambda, incluindo logging estruturado, rastreamento e métricas (AMAZON WEB SERVICES, 2024);

e) Pandas (versão 2.2.3) e OpenPyXL (versão 3.1.5): utilizadas para manipulação e exportação de dados em formato de planilhas Excel.

6.6.1.2 Infraestrutura e Deployment

O AWS CDK foi complementado com as seguintes bibliotecas:

- a) CDK-Nag (versão 2.28.195): ferramenta de análise estática que verifica se a infraestrutura definida segue as melhores práticas de segurança da AWS (AMAZON WEB SERVICES, 2024);
- b) AWS Lambda Python Alpha (versão 2.157.0a0): constructs experimentais para facilitar o emprego de funções Lambda escritas em Python.

6.6.1.3 Testes e Qualidade de código

Para garantir a qualidade do código, foram empregadas:

- a) Pytest (versão 6.2.5): framework de testes unitários e de integração;
- b) Moto (versão 5.0.16): biblioteca para mock de serviços AWS em ambiente de testes;
- c) NLTK (versão 3.9.1), ROUGE (versão 1.0.1) e Scikit-learn (versão 1.5.2): bibliotecas para avaliação de qualidade das respostas geradas por modelos de linguagem.

6.6.2. Front-end

O front-end foi desenvolvido como uma *Single Page Application* (SPA). O desenvolvimento da interface da aplicação foi realizado utilizando um conjunto de *frameworks* JavaScript, composto por TypeScript (versão 5.5.3), React (versão 18.3.1) e Vite (versão 5.4.1). O TypeScript foi adotado como linguagem principal devido à sua capacidade de adicionar tipagem estática ao JavaScript, contribuindo para o aumento da robustez, redução de erros em tempo de desenvolvimento e melhoria na manutenibilidade do código (MICROSOFT, 2024). Para a construção da interface de usuário, utilizou-se o React, uma biblioteca amplamente consolidada que permite o desenvolvimento de componentes reutilizáveis e a criação de interfaces dinâmicas e responsivas, facilitando a organização e escalabilidade da aplicação (META, 2024). Complementarmente, o Vite foi empregado como ferramenta de *build* do servidor de desenvolvimento, destacando-se pelo seu desempenho superior, especialmente por meio do suporte a *Hot Module Replacement* (HMR), que possibilita atualizações em tempo real durante o desenvolvimento, aumentando significativamente a velocidade de desenvolvimento (VITE, 2024).

6.6.2.1. Biblioteca de interface

Para a construção da interface do usuário, foram utilizadas:

- a) Radix UI: conjunto de componentes React acessíveis e não estilizados, incluindo alert-dialog, avatar, checkbox, dialog, dropdown-menu, label, select, slider, switch, toast e tooltip;
- b) Tailwind CSS (versão 3.4.10): framework CSS utility-first que permite estilização rápida através de classes predefinidas (TAILWIND LABS, 2024);
- c) Lucide React (versão 0.439.0): biblioteca de ícones SVG otimizados para React;
- d) React Router DOM (versão 6.26.2): biblioteca para gerenciamento de rotas em aplicações React (REMIX, 2024).

6.6.2.2. Personalizadores

- a) ESLint (versão 9.9.0): ferramenta de linting para identificação de padrões problemáticos no código JavaScript/TypeScript;
- b) Prettier (versão 3.3.3): formatador de código que garante consistência no estilo de codificação;
- c) PostCSS (versão 8.4.45) e Autoprefixer (versão 10.4.20): ferramentas para processamento e compatibilidade de CSS entre navegadores.

6.6.2.3. Controle de Versão e Containerização

- a) Git: sistema de controle de versão distribuído utilizado para gerenciamento do código-fonte;
- b) Docker: plataforma de containerização utilizada para empacotamento e *deployment* de componentes da aplicação;

6.7. Limitações e considerações éticas

Como limitações do estudo, destacam-se:

- Dependência de modelos de Inteligência Artificial de terceiros;
- Possíveis vieses, inconsistências ou omissões na geração automática de ameaças;
- Escopo restrito aos cenários e arquiteturas definidos no experimento.

Do ponto de vista ético e de segurança, não foram utilizados dados sensíveis reais, sendo o ambiente isolado e destinado exclusivamente a fins acadêmicos. Todas as análises foram realizadas em ambiente controlado, sem impacto em sistemas de produção. Por fim, a implantação do código e ambiente estará nos apêndices.

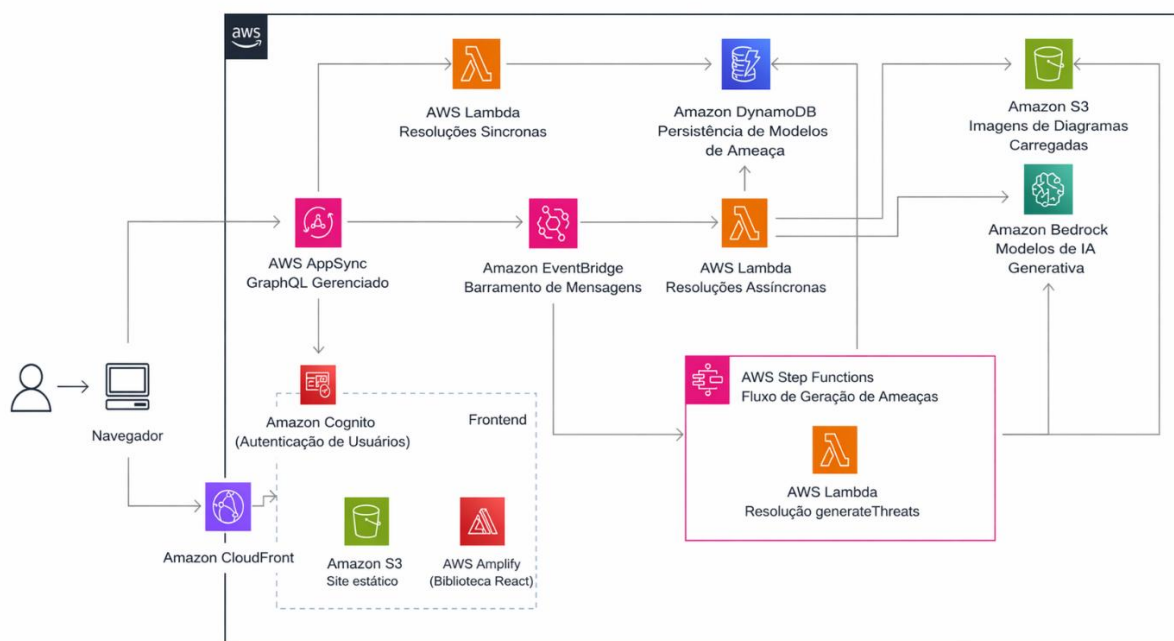
Com base na metodologia, tecnologias e limitações apresentadas, torna-se possível compreender os elementos técnicos e conceituais que fundamentaram o desenvolvimento da solução proposta. Assim, o capítulo seguinte apresenta a arquitetura da solução desenvolvida, detalhando seus componentes, criação, fluxos de comunicação, integrações e a forma como os diferentes módulos interagem para viabilizar o processo automatizado de análise e geração de ameaças em ambientes computacionais.

7. Arquitetura da Solução

A arquitetura da aplicação constitui um elemento central deste trabalho, pois materializa, em termos técnicos, os conceitos discutidos nos capítulos anteriores, especialmente no que se refere à integração entre Inteligência Artificial Generativa e modelagem de ameaças em ambientes de computação em nuvem. Este capítulo tem como objetivo descrever, de forma estruturada, a organização dos componentes da solução proposta, os fluxos de processamento de dados e as decisões arquiteturais adotadas, considerando requisitos de segurança, escalabilidade, custo (que será mais explorado nos itens 11.2 e 13.2) e governança.

A figura 7, apresenta o desenho da solução proposta, evidenciando a visão macro da arquitetura e as interações entre seus principais elementos.

Figura 7: Arquitetura proposta da solução.



Fonte: Autoria própria.

7.1. Componentes

A arquitetura da aplicação proposta é composta por um conjunto de serviços gerenciados da AWS, organizados segundo um modelo *serverless*, orientado a eventos e integrado a capacidades de IA Generativa.

A seguir, são descritos os principais componentes da arquitetura, organizados por camadas funcionais, bem como suas respectivas responsabilidades no contexto da solução.

7.1.1. Ator da Aplicação

O principal ator do sistema é o usuário da aplicação, que interage por meio de um navegador web. Este usuário é responsável por autenticar-se, enviar informações (como diagramas de arquitetura) e acionar funcionalidades de análise de ameaças. Sua interação ocorre exclusivamente através da camada de *frontend*, respeitando os limites das fronteiras de confiança estabelecidas.

7.1.2. Camada de *Frontend*

A camada de *frontend* é responsável pela entrega da aplicação e pela interação com o usuário, sendo composta pelos seguintes serviços:

- Amazon CloudFront: Atua como *Content Delivery Network* ou Rede de Distribuição de Conteúdo (*CDN*), distribuindo o conteúdo estático da aplicação com baixa latência e servindo como ponto de entrada controlado para acesso ao frontend.
- Amazon S3 (*Static Website*): Armazena os artefatos da aplicação web (HTML, CSS, JavaScript), configurado para acesso restrito via CloudFront.
- AWS Amplify: Utilizado como biblioteca no *frontend* (React), facilitando a integração com serviços como autenticação e APIs.
- Amazon Cognito: Responsável pela autenticação e autorização de usuários, gerenciando identidade, emissão de tokens e controle de acesso.

Essa camada representa uma fronteira de confiança crítica, por ser o ponto de entrada externo da aplicação.

7.1.3. Camada de API

A comunicação entre o frontend e os serviços de backend é mediada por:

- AWS AppSync (GraphQL gerenciado): Responsável por expor a API da aplicação, permitindo a execução de queries e mutations. O AppSync gerencia tanto *resolvers* síncronos quanto assíncronos, direcionando as requisições para os serviços adequados.

Essa camada estabelece a fronteira entre o ambiente cliente e o backend, sendo responsável por controle de acesso, validação e roteamento de requisições.

7.1.4. Camada de Processamento

A lógica de negócio da aplicação é implementada por meio de funções *serverless*:

- AWS Lambda - *Resolvers* Síncronos: Executam operações de baixa latência que exigem resposta imediata, como consultas ao banco de dados e interações diretas com serviços de IA.
- AWS Lambda - *Resolvers* Assíncronos: Executam tarefas desacopladas, acionadas via eventos, permitindo maior escalabilidade e resiliência.
- AWS Lambda - generateThreats Resolver: Função dedicada à geração de ameaças, responsável por interagir com os modelos de IA e processar os dados recebidos.

A separação entre execuções síncronas e assíncronas reduz o acoplamento e melhora a eficiência do sistema.

7.1.5. Barramento de Eventos e Orquestração

A arquitetura adota um paradigma orientado a eventos, suportado pelos seguintes serviços:

- Amazon EventBridge: Atua como barramento de eventos, responsável por desacoplar os componentes e distribuir mensagens para processamento assíncrono.
- AWS Step Functions: Responsável pela orquestração do fluxo de geração de ameaças, permitindo controle de estados, execução sequencial/condicional, *retries* e rastreabilidade do processo.

Essa camada é essencial para garantir resiliência, escalabilidade e controle de fluxos complexos.

7.1.6. Camada de Persistência

Os dados utilizados pela aplicação são armazenados em serviços gerenciados, conforme sua natureza:

- Amazon DynamoDB: Utilizado para persistência dos modelos de ameaças, oferecendo alta disponibilidade e baixa latência para operações de leitura e escrita.
- Amazon S3 (Uploaded Diagram Images): Responsável pelo armazenamento de imagens de diagramas enviados pelos usuários, utilizadas como insumo para análise.

A separação entre dados estruturados e não estruturados segue boas práticas de arquitetura em nuvem.

7.1.7. Camada de Inteligência Artificial

A capacidade de análise automatizada de ameaças é suportada por serviços de Inteligência Artificial Generativa acessados por meio do **Amazon Bedrock**, que atua como camada de abstração para consumo de modelos fundacionais.

No contexto desta solução, são utilizados dois modelos distintos, com responsabilidades complementares:

- Claude 4.5: empregado para processamento textual, interpretação de contexto e geração de ameaças com base em descrições arquiteturais, entradas estruturadas e enriquecimento semântico.
- Claude Haiku 4.5: utilizado para análise de imagens, especialmente na interpretação de diagramas de arquitetura enviados pelos usuários, permitindo a extração de elementos estruturais relevantes para o processo de modelagem de ameaças.

A arquitetura adota ainda a técnica de *Retrieval-Augmented Generation* (RAG), na qual o processo de geração de respostas é enriquecido por uma base de conhecimento incremental (biblioteca de ameaças, padrões e contextos previamente analisados de outros usos). Esse mecanismo permite que a solução evolua continuamente em qualidade e precisão, sem depender exclusivamente do conhecimento estático dos modelos, combinando capacidade de inferência contextual com consulta a dados previamente estruturados.

7.2. Fluxo de Processamento de dados da Solução

O fluxo de processamento da solução descreve o comportamento dinâmico da arquitetura, evidenciando como os dados trafegam entre os componentes, desde a interação inicial do usuário até a geração e persistência das ameaças identificadas.

Conforme mostrado anteriormente, a arquitetura adota um modelo híbrido, combinando processamento síncrono para operações de baixa latência e processamento assíncrono para tarefas intensivas e de maior complexidade, especialmente aquelas que envolvem IA.

7.2.1. Interação inicial e autenticação

O fluxo é iniciado pelo usuário por meio do navegador, acessando a aplicação web distribuída via Amazon CloudFront. O conteúdo estático é carregado a partir do Amazon S3, garantindo baixa latência e alta disponibilidade.

Para acessar funcionalidades protegidas, o usuário realiza autenticação por meio do Amazon Cognito. Após a autenticação bem-sucedida, tokens de acesso são emitidos e utilizados nas requisições subsequentes para controle de autorização.

7.2.2. Consumo da API e entrada de dados

Após autenticado, o usuário interage com a aplicação enviando requisições ao *backend* via AWS AppSync (GraphQL). Essas requisições podem incluir:

- Envio de diagramas de arquitetura (imagens);
- Submissão de descrições textuais do sistema;
- Solicitação de geração de ameaças.

Dependendo da natureza da operação, o AppSync direciona a requisição para *resolvers* síncronos ou assíncronos.

7.2.3. Processamento síncrono

Para operações que exigem resposta imediata (como consultas ou validações), o AppSync aciona diretamente funções AWS Lambda (*Resolvers* Síncronos). Essas funções podem:

- Consultar ou persistir dados no Amazon DynamoDB;
- Realizar chamadas diretas ao Amazon Bedrock (ex.: análises rápidas baseadas em texto);
- Retornar resultados em tempo real ao usuário.

7.2.4. Processamento assíncrono orientado a eventos

Para operações mais complexas, como a geração de ameaças a partir de múltiplas entradas (imagem + texto), o AppSync publica eventos no Amazon EventBridge. Esse mecanismo desacopla a requisição inicial do processamento intensivo.

A partir desse ponto:

1. O Amazon EventBridge encaminha o evento para:
 - a) Funções AWS Lambda (*Resolvers* Assíncronos), responsáveis por pré-processamento e persistência inicial;
 - b) AWS Step Functions, que orquestra o fluxo de geração de ameaças.
2. As Lambdas assíncronas realizam:
 - Armazenamento de imagens no Amazon S3;
 - Persistência de metadados e estado inicial no DynamoDB.

Esse modelo aumenta a resiliência e evita bloqueio da interface do usuário.

7.2.5. Orquestração do processo de geração de ameaças

O AWS Step Functions executa o workflow responsável pela geração de ameaças, coordenando múltiplas etapas de processamento. Esse fluxo inclui:

- Invocação da função Lambda generateThreats;
- Controle de estado da execução;
- Implementação de retries e tratamento de falhas.
- Essa orquestração permite visibilidade e controle sobre todo o processo.

7.2.6. Pipeline de Inteligência Artificial (RAG + Modelos Fundacionais)

A função generateThreats implementa o pipeline de análise baseado em IA, estruturado em múltiplas etapas:

- a) **Pré-processamento da entrada:**
 - i. Caso haja imagem, o modelo Claude Haiku 4.5 é utilizado para interpretar o diagrama e extrair elementos arquiteturais (componentes, fluxos, relações).
 - ii. Entradas textuais são normalizadas e estruturadas.

b) Enriquecimento via RAG:

- i. O sistema consulta uma base de conhecimento (armazenada ou derivada de dados anteriores, padrões de ameaças etc.);
- ii. Informações relevantes são recuperadas e incorporadas ao contexto da requisição.

c) Geração de ameaças:

- i. O modelo Claude 4.5 é utilizado para gerar ameaças com base:
 1. No contexto e descrição fornecidos pelo usuário;
 2. Nos dados extraídos da imagem;
 3. Similaridades com outros *submits* via RAG.

d) Pós-processamento e estruturação:

- i. As ameaças geradas são organizadas para a visualização do usuário (ex.: categorização STRIDE, normalização);
- ii. São preparados os dados para persistência e retorno.
- iii. Essa abordagem reduz alucinações, melhora a consistência e aumenta a qualidade das análises.

7.2.7. Persistência e retorno dos resultados

Após a geração:

- a) Os resultados são armazenados no Amazon DynamoDB, garantindo acesso rápido, escalável e reutilizável pela própria IA;
- b) Artefatos adicionais (como imagens ou LOGs) permanecem no Amazon S3;

7.3. Aderência a Boas Práticas de Cloud (FinOps)

A adoção de computação em nuvem, embora proporcione ganhos significativos em escalabilidade, flexibilidade e agilidade, também impõe desafios relacionados à gestão eficiente de custos. Nesse contexto, destaca-se o conceito de *Financial Operation* (FinOps) entendido como uma prática que integra gestão financeira e operação técnica da nuvem, promovendo maior controle e otimização contínua dos recursos. Conforme descrito pela AWS, “FinOps é uma prática cultural que reúne equipes de finanças, tecnologia e negócios para tomar decisões baseadas em dados sobre gastos em nuvem” (AWS, 2023). Essa abordagem enfatiza a visibilidade de custos, responsabilidade compartilhada e alinhamento entre consumo de recursos e geração de valor para o negócio.

No contexto da arquitetura proposta, observa-se aderência a boas práticas de FinOps

principalmente pela adoção de um modelo serverless e orientado a eventos, no qual os recursos são consumidos sob demanda. Serviços como AWS Lambda, Amazon EventBridge e AWS Step Functions operam no modelo *pay-per-use*, reduzindo custos associados à ociosidade de infraestrutura e eliminando a necessidade de provisionamento antecipado.

Outro ponto relevante é a separação entre processamento síncrono e assíncrono, que permite melhor controle sobre cargas de trabalho e evita execuções desnecessárias ou bloqueantes, otimizando o uso de funções Lambda e reduzindo custos computacionais. Da mesma forma, a utilização de orquestração via Step Functions possibilita controle mais granular sobre execuções, *retries* e falhas, evitando desperdício de recursos.

No que se refere ao uso de IA, a integração com o Amazon Bedrock permite consumo sob demanda de modelos fundacionais, evitando custos elevados associados ao treinamento ou hospedagem própria de modelos. A aplicação da técnica de RAG também contribui para a eficiência, ao reduzir chamadas redundantes aos modelos e melhora a qualidade das respostas, diminuindo retrabalho e consumo desnecessário de inferência.

Diante da arquitetura proposta e das decisões técnicas, torna-se necessário avaliar, na prática, a efetividade dessa abordagem no contexto de modelagem de ameaças. Nesse sentido, o capítulo a seguir apresenta a execução da solução em diferentes cenários arquiteturais, com o objetivo de analisar seu comportamento, validar sua aplicabilidade e examinar os resultados obtidos em termos de identificação de ameaças e classificação de riscos.

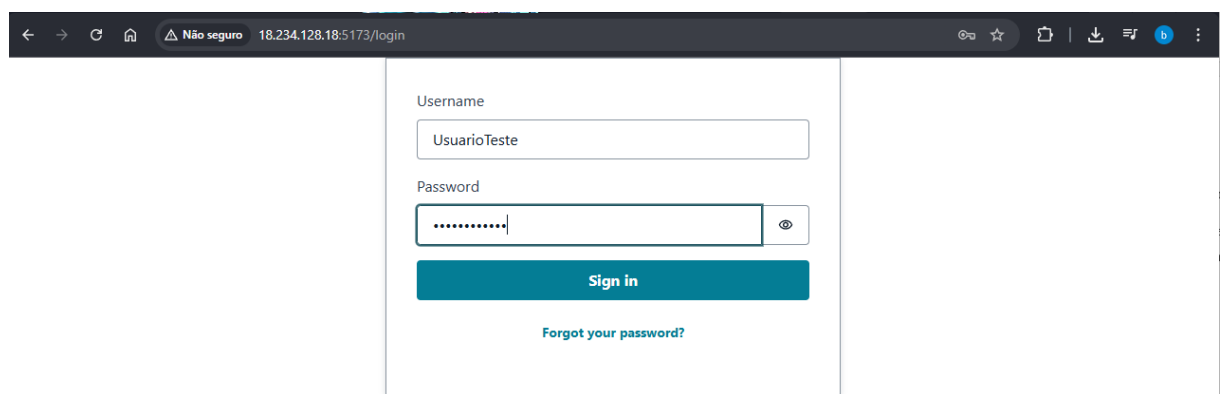
8. Passo a Passo de Execução e Outputs

Abaixo, será demonstrado um guia Passo-a-Passo de como executar uma modelagem de ameaça com a aplicação criada.

8.1. Autenticação da Solução

A Figura 8 apresenta o processo de autenticação do usuário na aplicação, realizado por meio da interface web integrada ao serviço de identidade.

Figura 8: Tela de autenticação da aplicação.



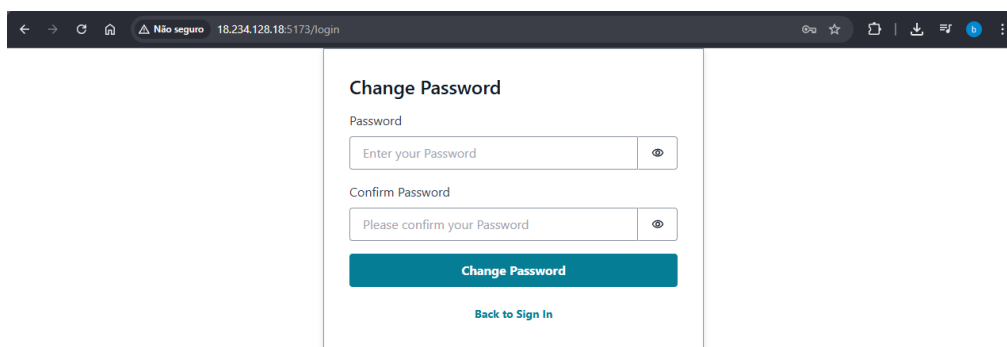
Fonte: Autoria própria.

Após a autenticação bem-sucedida, o usuário obtém acesso às funcionalidades principais da aplicação.

8.2. Atualização de credenciais de acesso

A Figura 9 apresenta a etapa de atualização da senha do usuário, na qual a aplicação solicita a definição e confirmação de uma nova credencial, em conformidade com as políticas de autenticação estabelecidas.

Figura 9: Tela de troca de senha da aplicação.

The image shows a web browser window with the address bar displaying '18.234.128.18:5173/login'. The page title is 'Change Password'. It contains two input fields: 'Password' with the placeholder 'Enter your Password' and 'Confirm Password' with the placeholder 'Please confirm your Password'. Both fields have toggle icons for password visibility. Below the fields is a blue 'Change Password' button and a link 'Back to Sign In'.

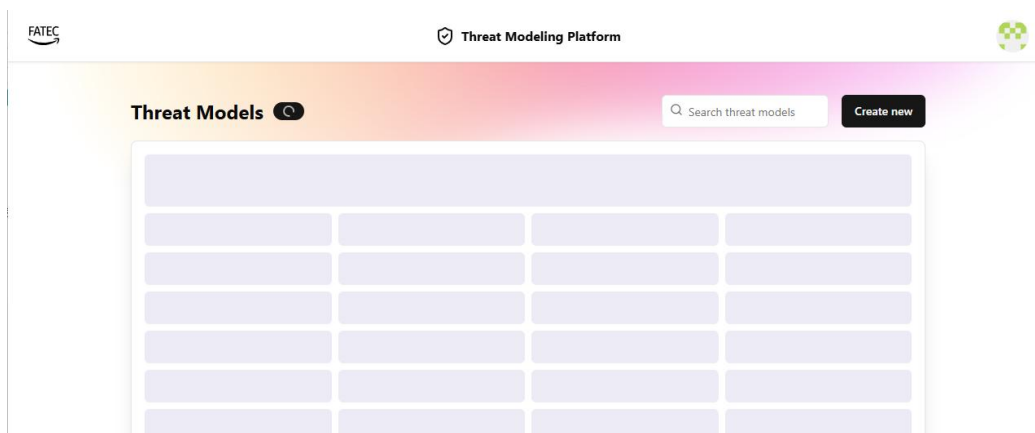
Fonte: Autoria própria.

Após a atualização das credenciais, o usuário é autenticado com sucesso e redirecionado para a interface principal da aplicação.

8.3. Acesso inicial à aplicação e criação de novo cenário

A Figura 10 apresenta a tela inicial da aplicação sem modelos de ameaças cadastrados, evidenciando o estado inicial do sistema antes da criação ou importação de análises.

Figura 10: Tela inicial da aplicação.



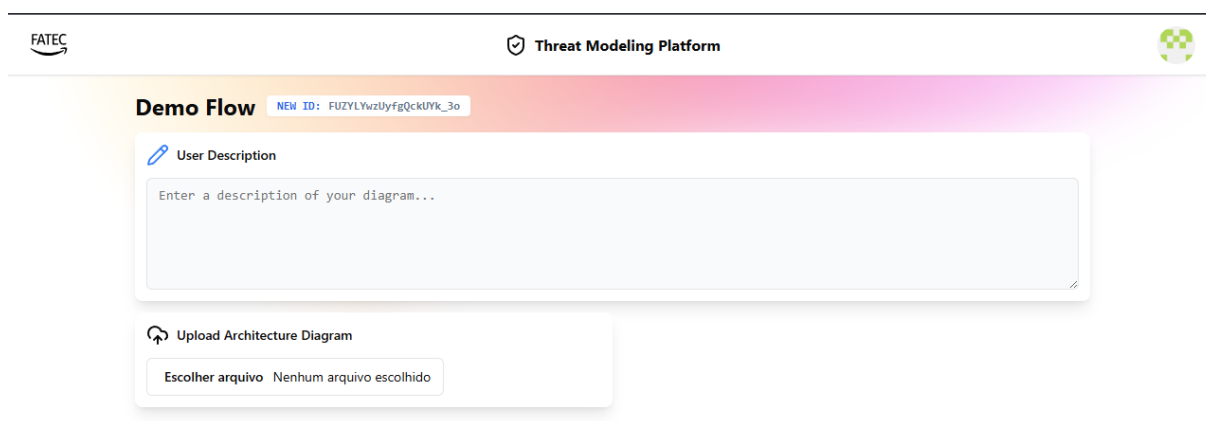
Fonte: Autoria própria.

Nesse momento, como ainda não há modelos de ameaças previamente cadastrados, a tela inicial permanece sem dados carregados. Para iniciar a utilização da ferramenta, é necessário criar um novo cenário de análise. Isso é realizado por meio da opção “*Create New*”, que permite ao usuário iniciar o processo de modelagem de ameaças a partir de um novo contexto arquitetural.

8.4. Submissão de dados para modelagem de ameaças

A Figura 11 apresenta a interface de submissão de cenários da aplicação, na qual o usuário deve fornecer uma descrição textual da arquitetura, preferencialmente em formato DFD, e realizar o envio da imagem correspondente ao diagrama arquitetural para execução da análise.

Figura 11: Inserção de Dados.

The screenshot shows the 'Threat Modeling Platform' interface. At the top, there's a header with the 'FATEC' logo on the left, the platform name 'Threat Modeling Platform' in the center, and a green checkmark icon on the right. Below the header, a pink banner displays 'Demo Flow' and a 'NEW ID: FUZYLYwzUyfgQckUYk_3o'. The main content area contains two sections: 'User Description' with a text input field labeled 'Enter a description of your diagram...' and 'Upload Architecture Diagram' with a file selection button labeled 'Escolher arquivo' and 'Nenhum arquivo escolhido'.

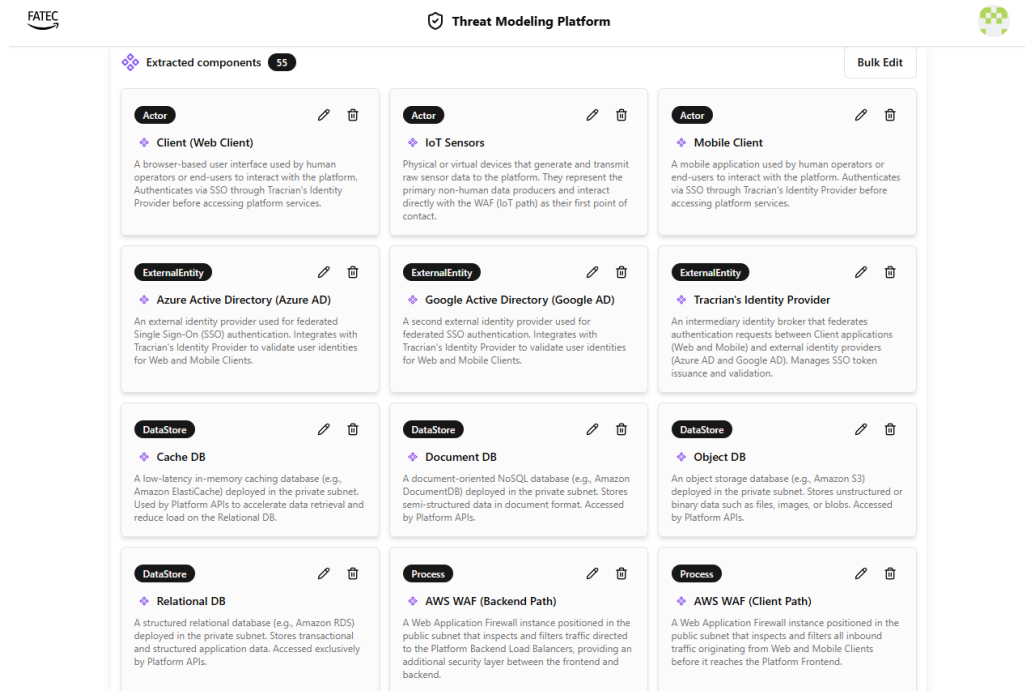
Fonte: Autoria própria.

A combinação entre descrição textual e representação visual permite enriquecer o contexto fornecido à solução, possibilitando uma análise mais precisa por parte dos modelos de Inteligência Artificial. Enquanto o texto contribui com a semântica e o detalhamento lógico do sistema, a imagem auxilia na identificação de componentes, fluxos e fronteiras de confiança.

8.5. Extração automática de componentes

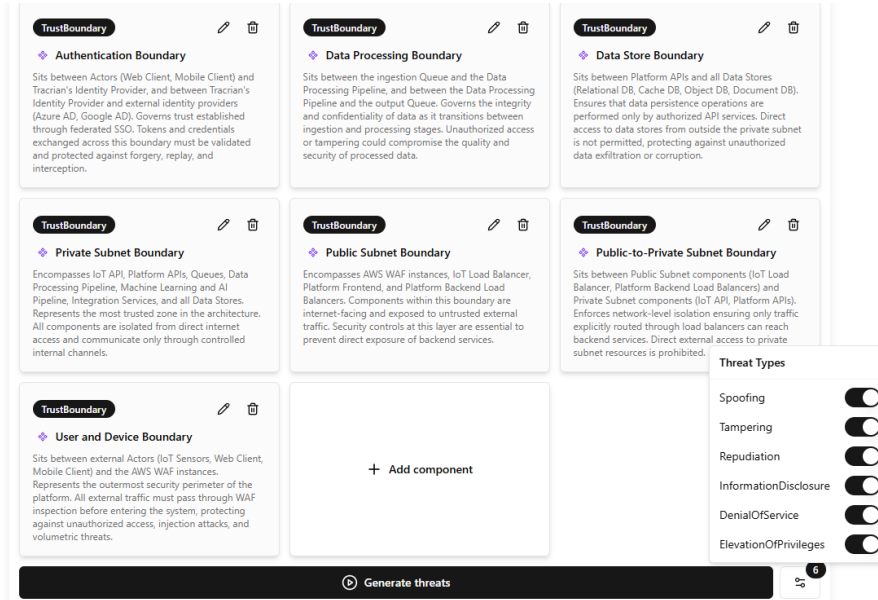
A Figura 12 e 13 apresenta a etapa de processamento automatizado do cenário submetido, na qual os modelos de Inteligência Artificial realizam a extração e classificação dos componentes arquiteturais identificados na descrição textual e no diagrama fornecido pelo usuário.

Figura 12: Extração dos componentes.



Fonte: Autoria própria.

Figura 13: Opção de novos componentes.



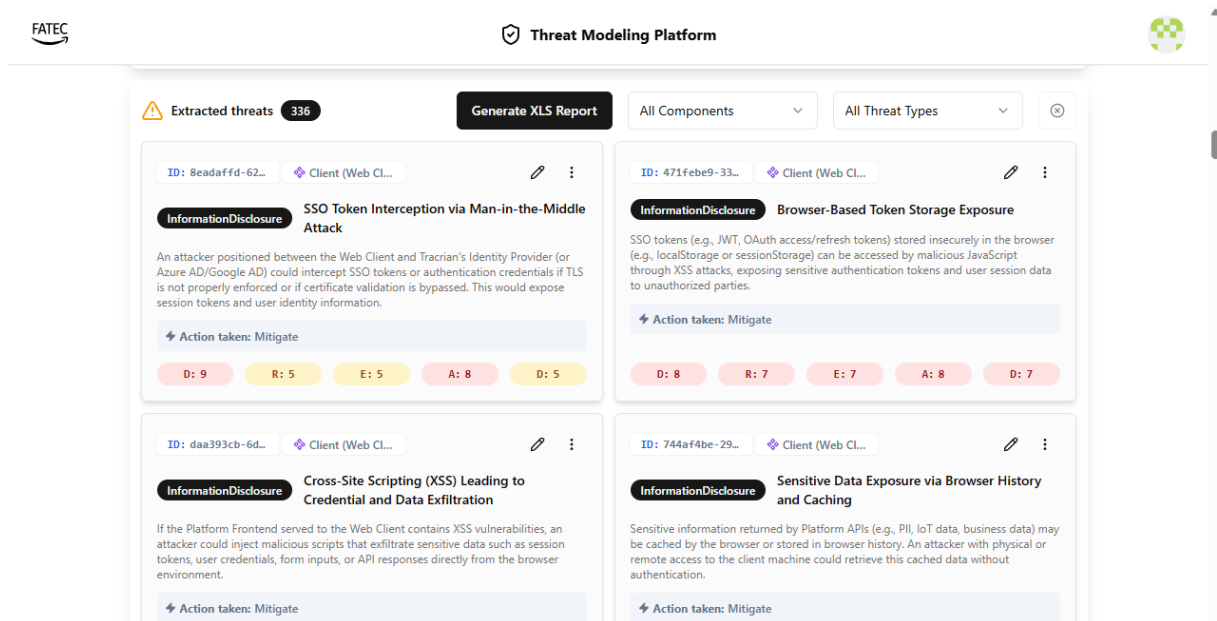
Fonte: Autoria própria.

Os componentes extraídos são apresentados de forma estruturada na interface, permitindo sua visualização, edição ou validação pelo usuário. Essa etapa é fundamental para garantir a consistência da modelagem, uma vez que os elementos identificados servirão como base para a geração das ameaças e etapas abaixo a análise.

8.6. Geração e visualização das ameaças

A Figura 14 apresenta o resultado da funcionalidade de geração de ameaças, na qual a aplicação exibe, de forma estruturada, as ameaças identificadas para o cenário analisado, incluindo descrição, categoria e classificação baseada no modelo STRIDE.

Figura 14: Geração de ameaças, exportação e visualização.



Fonte: Autoria própria.

As ameaças são organizadas de maneira a facilitar sua análise e interpretação, permitindo ao usuário visualizar diferentes aspectos de risco relacionados aos componentes do sistema. Adicionalmente, a interface disponibiliza funcionalidades complementares, como a exportação dos resultados em formato XML, bem como a aplicação de filtros por componentes específicos ou por categorias de ameaça baseadas no modelo STRIDE, possibilitando uma análise mais direcionada e eficiente.

8.7. Edição e gestão das ameaças identificadas

A Figura 15 apresenta a funcionalidade de edição das ameaças identificadas, permitindo ao usuário modificar informações relacionadas à descrição, categorização e parâmetros de classificação de risco associados a cada ameaça gerada pela aplicação.

Figura 15: Edição dos Riscos.

⚠ Extracted threats 408

ID: 8eadaffd-62...

Client (Web Cl...

✓

✕

InformationDisclosure ▾SSO Token Interception via Man-in-the

An attacker positioned between the Web Client and Tracrian's Identity Provider (or Azure AD/Google AD) could intercept SSO tokens or authentication credentials if TLS is not properly enforced or if certificate validation is bypassed. This would expose session tokens and user identity information.

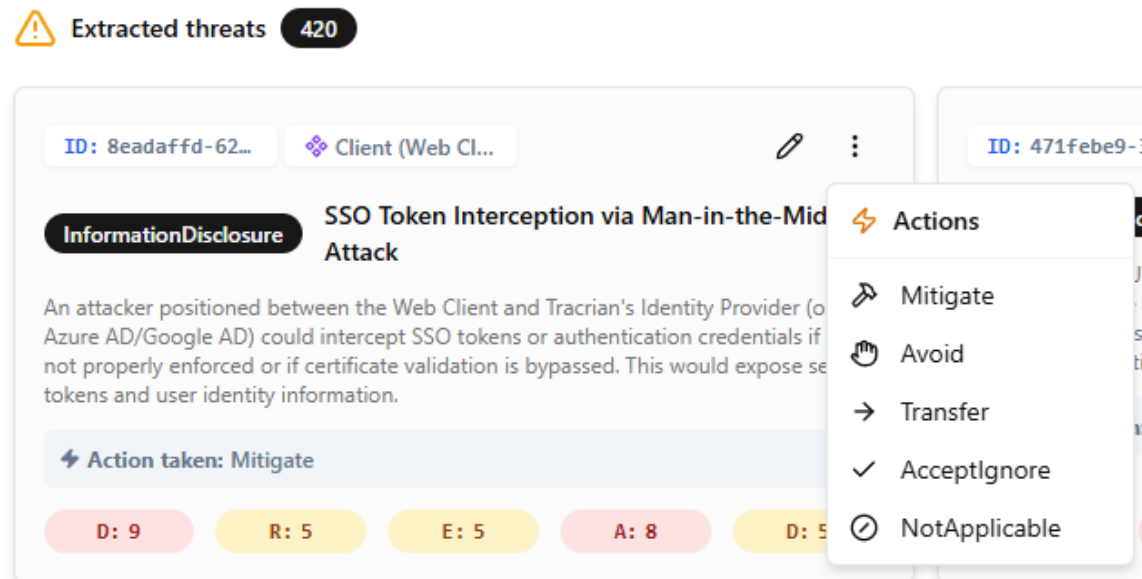
⚡ Action taken: Mitigate

Damage		9
Reproducibility		5
Exploitability		5
AffectedUsers		8
Discoverability		5

Fonte: Autoria própria.

A Figura 16 apresenta as opções de tratamento de risco disponibilizadas pela aplicação, permitindo ao usuário definir estratégias de resposta para cada ameaça identificada, incluindo mitigação, evitação, transferência, aceitação ou classificação como falso positivo.

Figura 16: Ações sobre Riscos.



Fonte: Autoria própria.

Essa funcionalidade permite alinhar os resultados gerados automaticamente pela Inteligência Artificial com a análise humana, possibilitando ajustes, validações e decisões estratégicas no processo de gestão de riscos.

8.8. Exportação dos resultados em formato estruturado

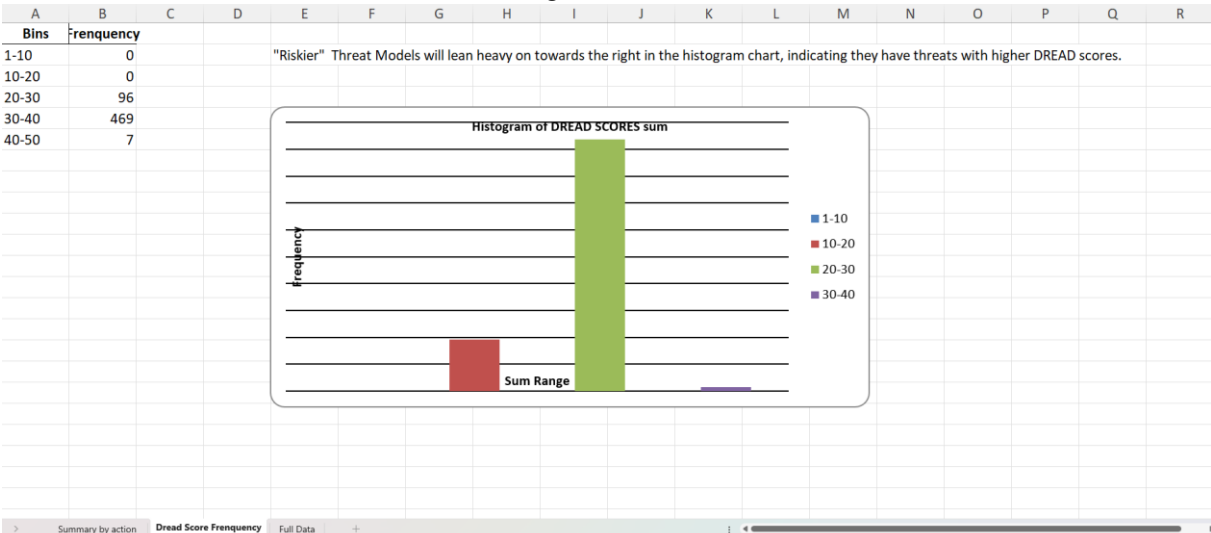
A Figura 17, 18 e 19 apresenta a funcionalidade de exportação dos resultados da análise, na qual a aplicação gera um arquivo em formato XLS contendo o resumo consolidado das ações adotadas, a distribuição dos scores de risco baseados no modelo DREAD e a base completa das ameaças identificadas.

Figura 17: Aba de resumo.

[illegible]

Fonte: Autoria própria.

Figura 18: Aba de *Score*.



Fonte: Autoria própria.

Figura 19: Aba de contendo todos os dados gerados.

A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	
name	stride_type	description	id	component_id	action	reason	scores	daores	reprocores	explores	affector	disco	componet	components	components	evaluated	l_dread	scad_sco
Cache pois Information	If cache keys a07a23242-e02eaba65-bc	Mitigate					8	6	6	8	5	Cache DB	A low-latency ir	DataStore	Not Evaluated		33	30-40
Unauthori:ElevationOfP	An attacker w/10c2ca35-8502eaba65-bc	Mitigate					8	7	6	8	5	Cache DB	A low-latency ir	DataStore	Not Evaluated		34	30-40
Unencrypt Information	If the Cache DI12aa0240-1f02eaba65-bc	Mitigate					7	5	4	8	4	Cache DB	A low-latency ir	DataStore	Not Evaluated		28	20-30
Memory E DenialOfServ	A compromise 16a0b399-f102eaba65-bc	Mitigate					7	8	6	8	5	Cache DB	A low-latency ir	DataStore	Not Evaluated		34	30-40
Lack of cal Repudiation	Cache DB oper 34d876d8-bf02eaba65-bc	Mitigate					6	9	8	8	7	Cache DB	A low-latency ir	DataStore	Not Evaluated		38	30-40
Unauthori: Tampering	An attacker w/4d5c9a9a-e202eaba65-bc	Mitigate					8	8	6	7	4	Cache DB	A low-latency ir	DataStore	Not Evaluated		33	30-40
Session To Tampering	If the Cache DI52d9853c-b702eaba65-bc	Mitigate					9	7	6	8	5	Cache DB	A low-latency ir	DataStore	Not Evaluated		35	30-40
Unencrypt Information	If TLS/SSL encr 611d0a21-2f02eaba65-bc	Mitigate					8	7	5	9	5	Cache DB	A low-latency ir	DataStore	Not Evaluated		34	30-40
Cache DB : ElevationOfP	Amazon Elastii 631b4311-9f02eaba65-bc	Mitigate					9	9	8	9	6	Cache DB	A low-latency ir	DataStore	Not Evaluated		41	40-50
Privilege e: ElevationOfP	If the Cache DI6789f775-702eaba65-bc	Mitigate					8	7	6	7	4	Cache DB	A low-latency ir	DataStore	Not Evaluated		32	30-40
IP spoofing Spoofing	Within the pri 7c4986b0-df02eaba65-bc	Mitigate					7	4	4	7	3	Cache DB	A low-latency ir	DataStore	Not Evaluated		25	20-30
Unauthori: Information	If the Cache DI81ca93ff-08f02eaba65-bc	Mitigate					8	7	6	8	6	Cache DB	A low-latency ir	DataStore	Not Evaluated		35	30-40
No audit lk Repudiation	Cache DB (e.g. 97f6be5a-9602eaba65-bc	Mitigate					6	8	7	7	6	Cache DB	A low-latency ir	DataStore	Not Evaluated		34	30-40
Spoofed PISpoofing	An attacker w/198c7710f-2202eaba65-bc	Mitigate					7	5	5	7	4	Cache DB	A low-latency ir	DataStore	Not Evaluated		28	20-30
Cache Star DenialOfServ	An attacker de9b6ceb26-5c02eaba65-bc	Mitigate					8	6	5	9	4	Cache DB	A low-latency ir	DataStore	Not Evaluated		32	30-40
Stolen or r Spoofing	If the Cache DIadc04e9f-1002eaba65-bc	Mitigate					8	7	6	8	5	Cache DB	A low-latency ir	DataStore	Not Evaluated		34	30-40
Cache Key DenialOfServ	A malicious or aebb8f18-9202eaba65-bc	Mitigate					7	8	6	8	5	Cache DB	A low-latency ir	DataStore	Not Evaluated		34	30-40
Cache Pois Tampering	A compromise b0ab44fa-e702eaba65-bc	Mitigate					8	7	6	8	5	Cache DB	A low-latency ir	DataStore	Not Evaluated		34	30-40
Cache TTL Tampering	An attacker w/c3377404-202eaba65-bc	Mitigate					6	8	6	7	5	Cache DB	A low-latency ir	DataStore	Not Evaluated		32	30-40
Overly per ElevationOfP	If IAM policies cdab1688-202eaba65-bc	Mitigate					8	7	6	8	5	Cache DB	A low-latency ir	DataStore	Not Evaluated		34	30-40
Cache Floc DenialOfServ	An attacker or d0caa57c-e602eaba65-bc	Mitigate					7	7	6	8	5	Cache DB	A low-latency ir	DataStore	Not Evaluated		33	30-40
Unauthent Spoofing	A malicious or dc9a278f-8002eaba65-bc	Mitigate					7	6	6	7	5	Cache DB	A low-latency ir	DataStore	Not Evaluated		31	30-40
Cache key Repudiation	If cache keys a e40d9fd0-1202eaba65-bc	Mitigate					6	7	6	6	5	Cache DB	A low-latency ir	DataStore	Not Evaluated		30	20-30
No audit lk Repudiation	Write and upd edfc3881-a702eaba65-bc	Mitigate					7	8	6	7	5	Cache DB	A low-latency ir	DataStore	Not Evaluated		33	30-40
Overly per ElevationOfP	If the AWS IAM 104917ef-15033d749b-8f	Mitigate					9	8	7	8	6	Queue (Pri	A second messs: Process		Not Evaluated		38	30-40
Summary by action Dread Score Frequency Full Data + 1 33,6048951 Contagion: 573 Soma: 19222 1459																		

Fonte: Autoria própria.

A estruturação dos dados em múltiplas abas facilita diferentes níveis de análise, desde uma visão executiva até uma análise técnica detalhada. Além disso, a disponibilização em formato estruturado possibilita a integração com ferramentas de *Business Intelligence* (BI), como o Power BI, permitindo a construção de dashboards, análise de tendências e apoio à tomada de decisão baseada em dados no contexto de gestão de riscos de segurança.

8.9. Considerações finais da demonstração

O passo a passo apresentado evidenciou a viabilidade operacional da ferramenta, demonstrando que o fluxo de utilização é consistente e estruturado, permitindo a interação do usuário em diferentes etapas, especialmente nos momentos de validação e ajuste dos resultados gerados.

Dessa forma, conclui-se que a abordagem proposta apresenta não apenas viabilidade técnica, mas também aplicabilidade prática, consolidando-se como uma base adequada para análises mais aprofundadas, as quais serão discutidas no capítulo seguinte.

9. Análise dos Resultados obtidos

Com o objetivo de validar, em ambiente prático, a aplicabilidade e a efetividade da arquitetura proposta, este capítulo apresenta a execução de diversos testes, bem como a análise dos resultados obtidos. Para isso, conforme informado na Metodologia, foram considerados 20 cenários de execução distintos, cada um representando combinações específicas de serviços em nuvem ou *on-premise*, configurações arquiteturais e diferentes níveis de complexidade e superfícies de ataque, disponibilizados publicamente, permitindo avaliar o comportamento da solução em contextos variados e representativos.

A Tabela 2 apresenta os 20 cenários selecionados para a realização dos testes experimentais deste trabalho. Os casos escolhidos representam estudos práticos de modelagem de ameaças aplicados a diferentes contextos tecnológicos, incluindo aplicações web, ambientes em nuvem, sistemas corporativos, arquiteturas distribuídas, plataformas IoT e soluções baseadas em Inteligência Artificial. Além da diversidade de cenários, os estudos selecionados possuem dados quantitativos relacionados ao esforço de execução e à taxa de falsos positivos, permitindo a comparação objetiva dos resultados obtidos ao longo da pesquisa.

As principais métricas que foram extraídas e utilizadas para comparação são: Tempo e Qualidade, conforme também definido na Metodologia.

Tabela 2: Lista de estudos utilizados.

ID	Projeto/Sistema	Tempo (horas)	Taxa de Falsos Positivos (%)	Fonte/Referência
ID1	Microsoft Windows Vista	240	15–20	Shostack (2008) – Microsoft SDL
ID2	Sistema bancário online	32	22	Scandariato et al. (2015)
ID3	Aplicação web <i>e-commerce</i>	16	18	Berger et al. (2016)
ID4	Sistema de saúde eletrônico	48	22	Myagmar et al. (2005)
ID5	Plataforma IoT industrial	56	30	Xiong e Lagerström (2019)
ID6	API REST corporativa	12	12	Sion et al. (2020)

ID	Projeto/Sistema	Tempo (horas)	Taxa de Falsos Positivos (%)	Fonte/Referência
ID7	Sistema de controle SCADA	72	28	Uzunov et al. (2012)
ID8	Aplicação <i>mobile banking</i>	24	20	Tuma et al. (2018)
ID9	Arquitetura de microserviços em nuvem	40	35	Fernandes et al. (2014)
ID10	Sistema de autenticação SSO	20	14	Howard e Lipner (2006)
ID11	Plataforma de streaming	36	26	Shevchenko et al. (2018)
ID12	Sistema ERP empresarial	80	11	Torr (2015)
ID13	Infraestrutura AWS multi-tier	28	16	AWS Security (2022)
ID14	Aplicação serverless	18	19	Sion et al. (2022)
ID15	Sistema de pagamentos (PCI-DSS)	64	17	Scandariato et al. (2015)
ID16	Plataforma de colaboração	44	29	Berger et al. (2016)
ID17	Sistema de gestão de identidades (IAM)	52	17	Ferraiolo e Kuhn (2009)
ID18	Aplicação containerizada (Docker)	22	23	Combe et al. (2016)
ID19	Sistema de mensageria distribuído	38	27	Newman (2015)
ID20	Plataforma de <i>machine learning</i>	46	31	Brundage et al. (2018)

Observações:

1. Os dados apresentados são baseados em estudos publicados e revisados por pares.
2. Aproximações foram necessárias pois nem todos os estudos reportam métricas idênticas.
3. A variabilidade nos tempos reflete diferenças em:

- a) Complexidade arquitetural;
 - b) Experiência da equipe;
 - c) Metodologia aplicada (STRIDE, PASTA, LINDDUN, etc.);
 - d) Nível de detalhe requerido.
4. Taxa de falsos positivos é influenciada por:
- a) Conhecimento do domínio pelos analistas;
 - b) Especificidade da metodologia;
 - c) Contexto operacional do sistema;
 - d) Uso de ferramentas automatizadas vs. análise manual.

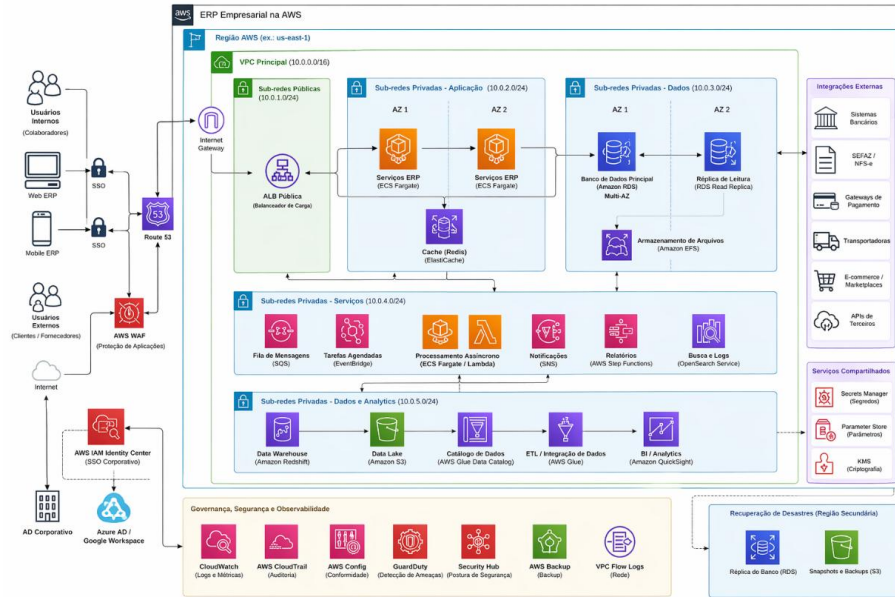
Estes dados servirão como *baseline* para comparações posteriores com a abordagem assistida por IA proposta neste trabalho.

Os desenhos arquiteturais foram refeitos para um aumento na qualidade da resposta da IA. O conteúdo permanece o mesmo, mas seus *designs* foram refeitos e em português utilizando o Serviço AWS Designer.

Foi realizada uma amostragem intencional de 4 cenários dentre os 20 avaliados, selecionados com base em critérios de representatividade, diversidade arquitetural e uso de infraestrutura na nuvem. Além disso, alguns trabalhos utilizados não disponibilizaram a quantidade exata de ameaças, pois focam mais em metodologia, processos ou análises qualitativas. Os cenários escolhidos correspondem aos identificadores ID12, ID15, ID20 e ID2 da Tabela 2.

Na figura 20, temos a demonstração da arquitetura do ID12, um sistema ERP corporativo.

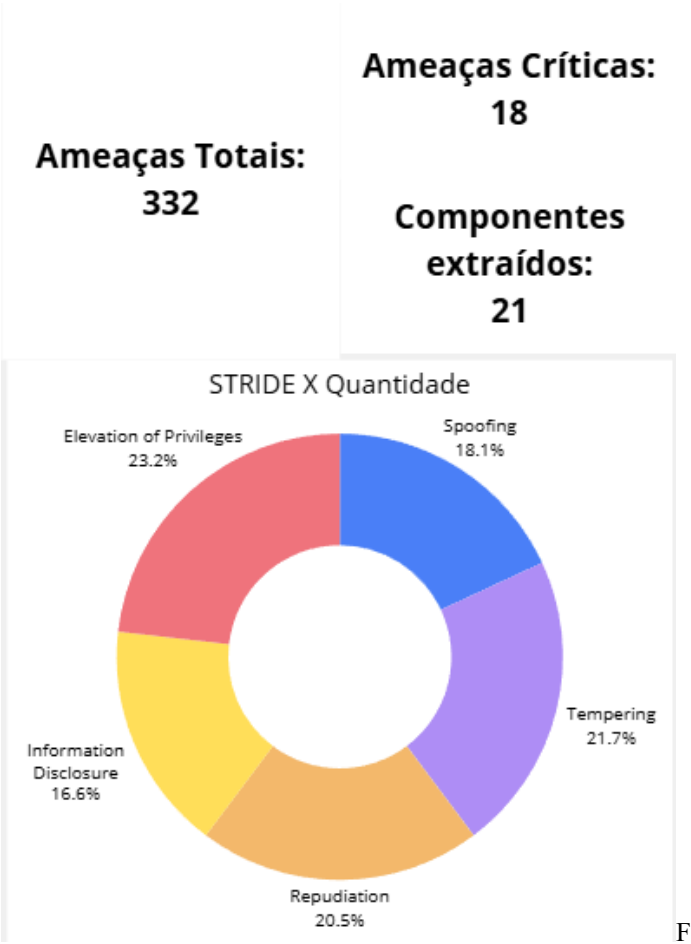
Figura 20: Arquitetura ID12.



Fonte: Autoria própria.

Na figura 21, é demonstrado os resultados da modelagem de ameaças realizado com solução proposta.

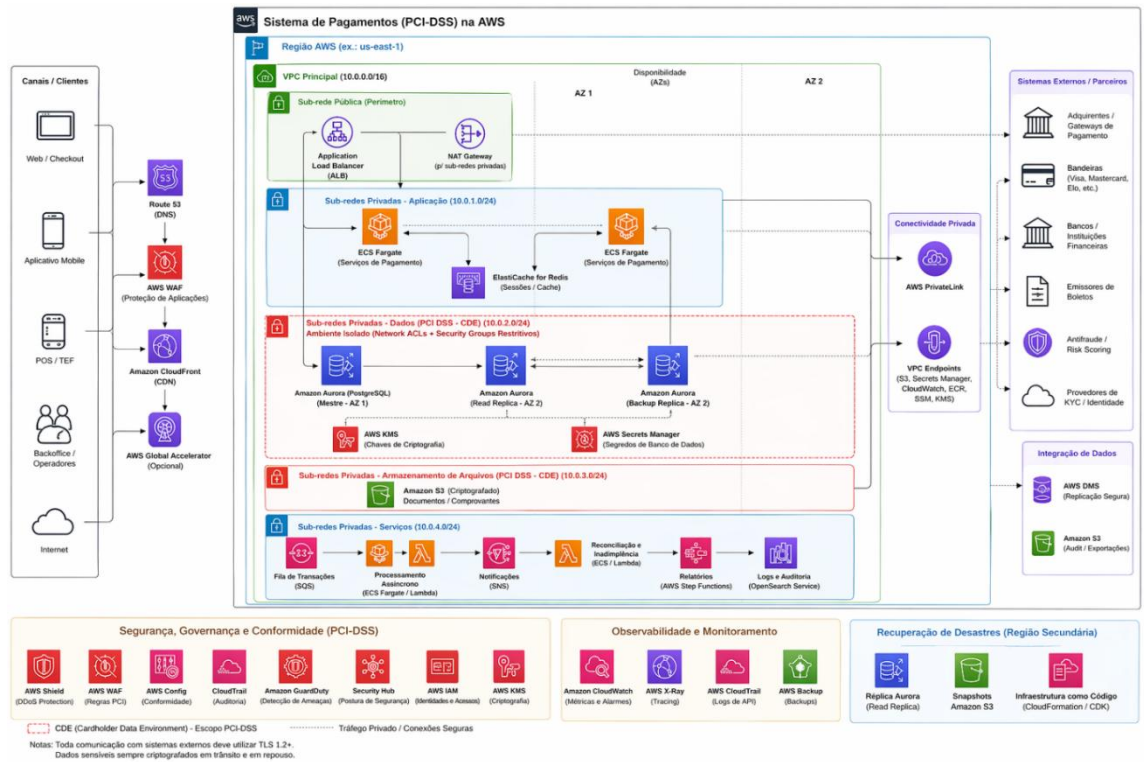
Figura 21: Resultados em Detalhes do ID12



Fonte: Autoria própria.

Na figura 22, temos a demonstração da arquitetura do ID15, um sistema de pagamentos que deve seguir as normas PCI-DSS.

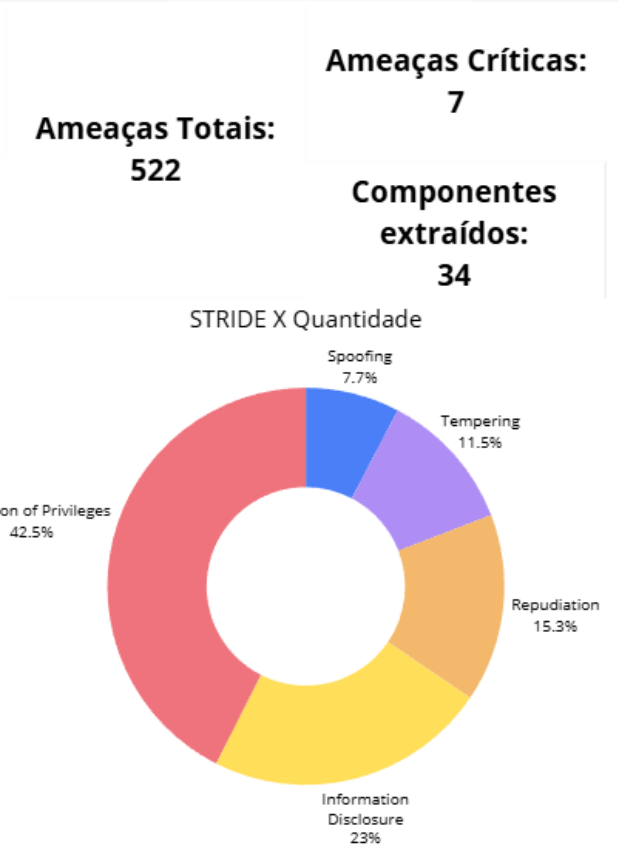
Figura 22: Arquitetura do ID15.



Fonte: Autoria própria.

Na figura 23, é demonstrado os resultados da modelagem de ameaças realizado com solução proposta.

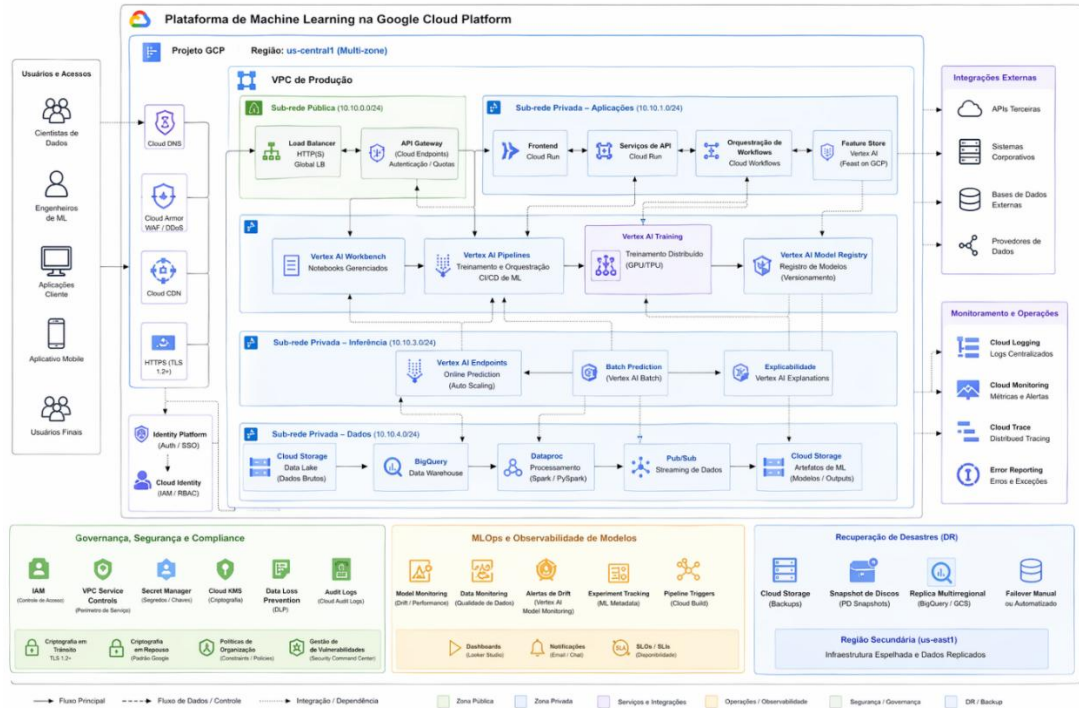
Figura 23: Resultado em detalhes do ID15.



Fonte: Autoria própria.

Na figura 24, temos a demonstração da arquitetura do ID20, uma plataforma de *machine learning*.

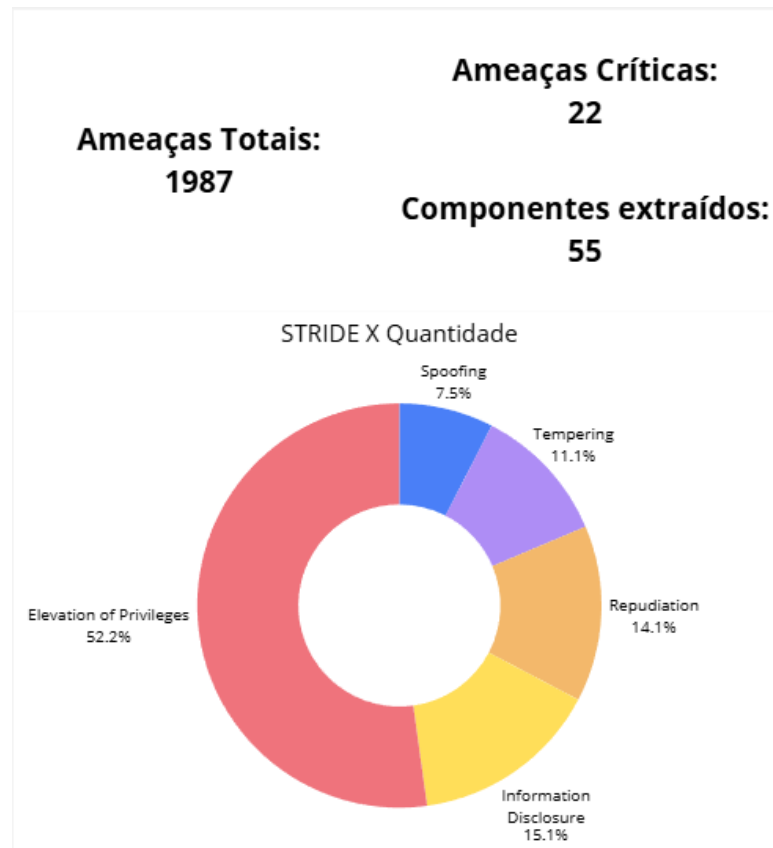
Figura 24: Arquitetura do ID20.



Fonte: Autoria própria.

Na figura 25, é demonstrado os resultados da modelagem de ameaças realizado com solução proposta.

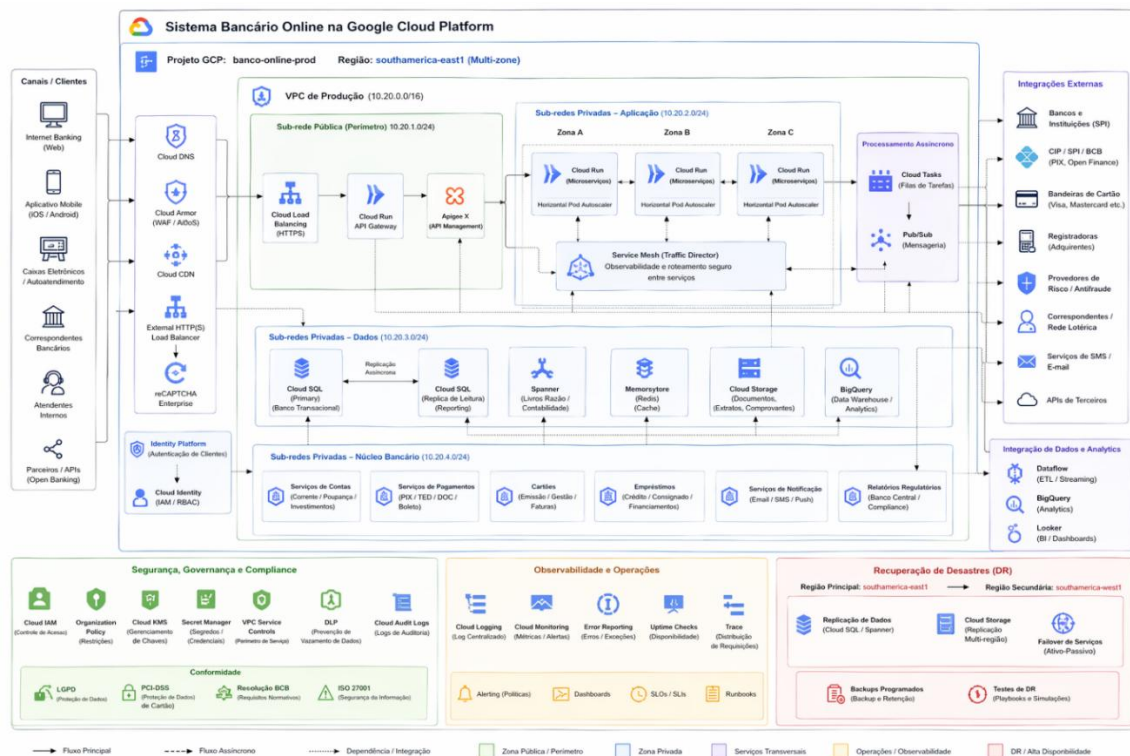
Figura 25: Resultado em detalhes do ID20.



Fonte: Autoria própria.

Na figura 26, temos a demonstração da arquitetura do ID02, um sistema bancário online.

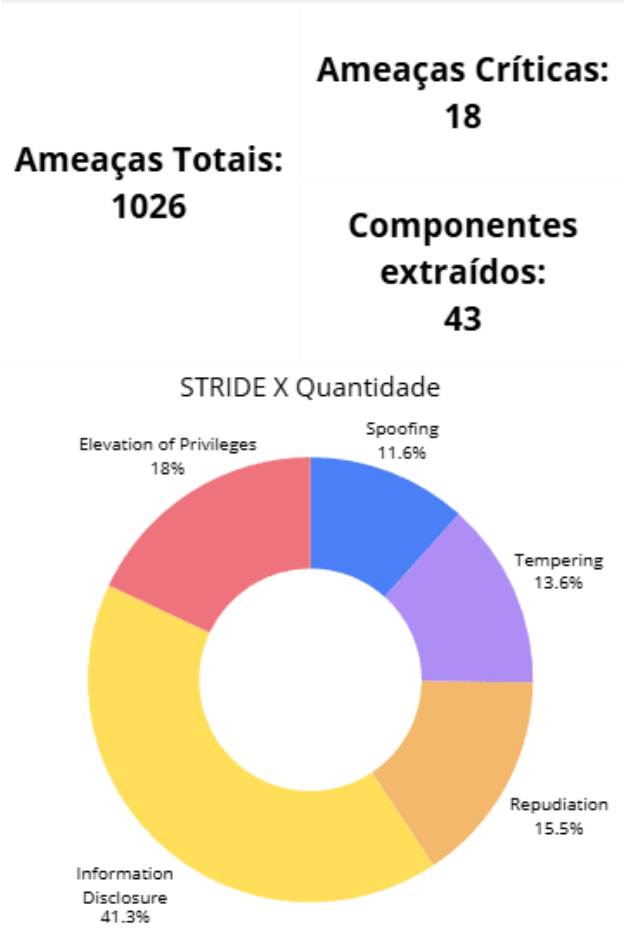
Figura 26: Arquitetura do ID2.



Fonte: Autoria própria.

Na figura 27, é demonstrado os resultados da modelagem de ameaças realizado com solução proposta.

Figura 27: Resultado em detalhes do ID2.



Fonte: Autoria própria.

Observação: Os dados utilizados na integra estão disponibilizados na secção Apêndice deste trabalho.

Conforme observado nos gráficos apresentadas, os resultados gerados pela solução baseada em Inteligência Artificial demonstram consistência técnica e coerência com práticas consolidadas de segurança da informação. Nota-se que o volume de ameaças identificadas apresenta relação proporcional com a quantidade de componentes extraídos, o que indica uma análise compatível com a complexidade dos cenários avaliados, e não uma geração arbitrária de dados. Além disso, a distribuição das ameaças segundo a metodologia STRIDE evidencia predominância de categorias como *Information Disclosure* e *Elevation of Privileges*, o que está

alinhado com padrões amplamente documentados em referências como o OWASP Top 10, especialmente no que se refere a falhas de controle de acesso e exposição de dados sensíveis.

Após a apresentação dos 4 casos individualmente, segue uma tabela para uma análise comparativa entre eles:

Tabela 3: Comparação dos testes destacados.

ID	Componentes Extraídos	Total de Ameaças	Ameaças Críticas	Tempo de Execução (min)	Taxa de Falsos Positivos
ID12	21	332	18	3,53	5%
ID15	34	522	7	4,21	11%
ID20	55	1987	22	11,50	37%
ID02	43	1026	18	5,22	24%

Observação: A Taxa de falsos positivos foi realizado de forma manual e comparado aos falsos positivos achados nos trabalhos originais referenciados na tabela 2.

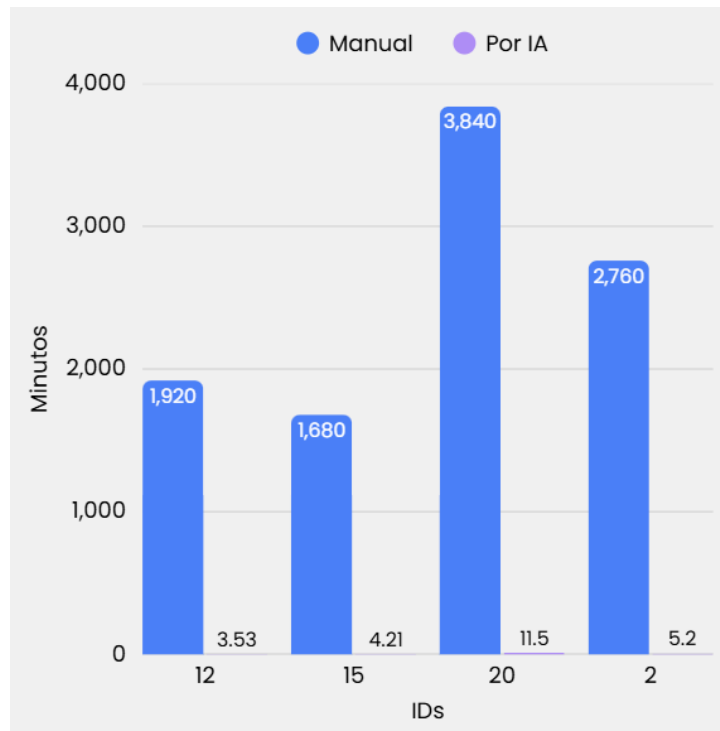
Podemos observar na tabela acima que quando mais componentes e mais possíveis ameaças, maior é a taxa de falsos positivos criados pela IA demonstrando que um grande escopo e um excesso de informações pode causar alucinações, ruído e perda de contexto, conforme escrito no capítulo 8.

9.1. Comparação dos resultados

A seguir, será realizado uma análise comparativa entre a abordagem automatizada baseada em IA e o processo tradicional de modelagem de ameaças conduzido manualmente por especialistas. A comparação é estruturada a partir de duas dimensões principais: a taxa de falsos positivos e o tempo de execução necessário para a realização da análise.

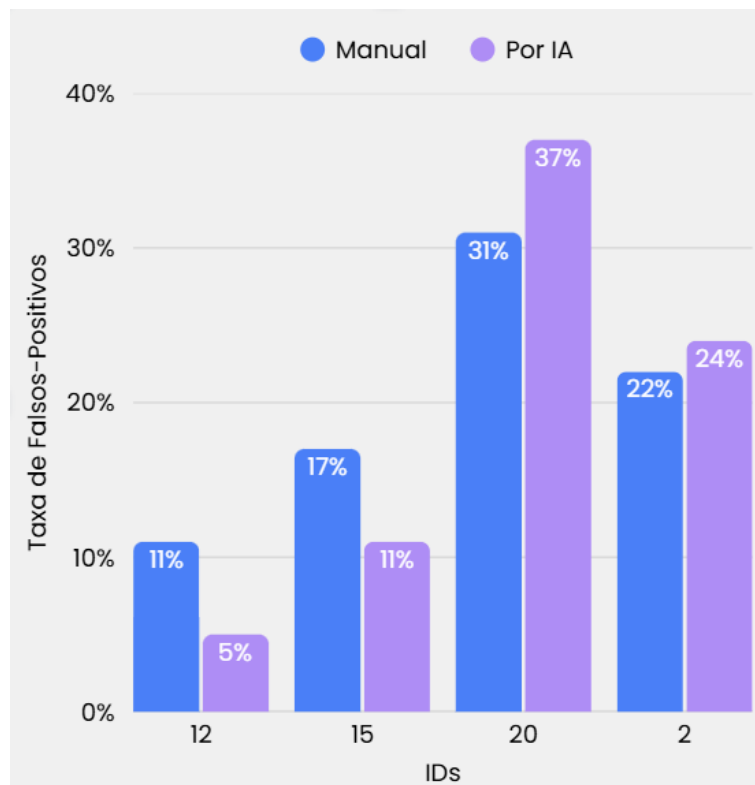
Esses critérios foram selecionados por representarem fatores críticos na avaliação da eficiência e da qualidade de abordagens de segurança, permitindo observar não apenas a capacidade de cobertura da solução proposta, mas também sua precisão e viabilidade operacional. Conforme dito anteriormente neste trabalho, alguns dos estudos utilizados não apresentam um número exato de ameaças detectadas. Portanto, será utilizado a tabela 2 em comparação com seus respectivos da tabela 3. As Figuras 28 e 29 apresentam, de forma gráfica, a comparação entre a abordagem tradicional de modelagem de ameaças realizada manualmente e a abordagem automatizada proposta neste trabalho.

Figura 28: Comparação do tempo de execução entre a abordagem manual e a abordagem baseada em IA nos testes seleccionados.



Fonte: Autoria própria.

Figura 29: Comparação percentual da taxa de falsos positivos entre a abordagem manual e a abordagem baseada em IA nos cenários analisados



Fonte: Autoria própria.

A análise comparativa entre a abordagem manual e a abordagem baseada em Inteligência Artificial evidencia ganhos significativos de eficiência operacional, especialmente no que se refere ao tempo de execução. Conforme observado, enquanto o processo manual demanda entre 1.680 e 3.840 minutos nos cenários avaliados, a abordagem com IA apresenta tempos substancialmente inferiores, variando entre aproximadamente 3,5 e 11,5 minutos. Essa diferença representa uma redução expressiva de tempo, indicando que a utilização de IA torna o processo de modelagem de ameaças significativamente mais ágil e escalável, sobretudo em ambientes com maior complexidade arquitetural.

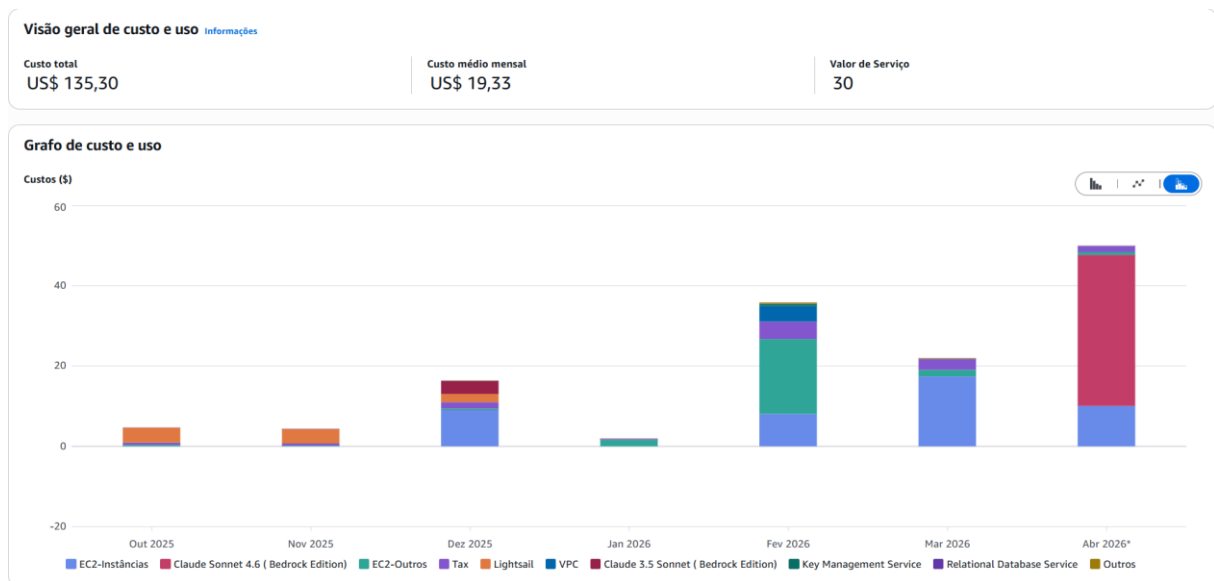
Entretanto, ao analisar a taxa de falsos positivos, observa-se a presença de *trade-offs* relevantes. Em alguns cenários, como os IDs 12 e 15, a abordagem baseada em IA apresentou taxas inferiores às da abordagem manual, sugerindo maior precisão na identificação de ameaças relevantes. Por outro lado, no cenário ID20, a IA apresentou uma taxa superior de falsos positivos (37% contra 31%), evidenciando limitações em contextos de maior complexidade e volume de dados, onde a geração excessiva de ameaças pode impactar a qualidade dos resultados. No cenário ID2, os valores se mantêm próximos, indicando desempenho equivalente entre as abordagens, mas já demonstrando os limites da IA com a alta complexidade dos cenários.

9.2. Análise de Custos da Abordagem Proposta

Agora será demonstrado abaixo os impactos financeiros associados à utilização da abordagem realizada durante este trabalho. A análise de custos é um fator crítico para a adoção de novas tecnologias, especialmente em contextos corporativos, onde decisões são fortemente influenciadas pela relação entre investimento e retorno operacional.

Abaixo, será demonstrado o custo (em dólares) do projeto do período de outubro de 2025 até o dia 23 de abril de 2026, período este que foi realizado grande partes dos testes, tanto da infraestrutura quando da aplicação, com o uso do AWS Cost Explorer. Os dados brutos estarão disponíveis nos apêndices.

Figura 30: Custos do projeto entre outubro de 2025 e abril de 2026



Fonte: Autoria própria.

O custo total acumulado foi de aproximadamente US\$ 135,30, com uma média mensal de US\$ 19,33, valores que indicam uma barreira de entrada reduzida para utilização da solução em ambientes de teste e validação.

Verifica-se, a partir da distribuição mensal, uma variação no consumo de recursos ao longo do tempo, com picos mais expressivos nos meses de fevereiro e abril de 2026. Esses aumentos estão diretamente associados à intensificação dos testes e ao uso mais frequente de serviços computacionais e de IA, como instâncias de processamento, serviços de inferência baseados em modelos (ex.: Bedrock/Claude) e componentes de suporte como banco de dados e gerenciamento de chaves. Em contrapartida, meses com menor atividade experimental apresentam custos marcadamente reduzidos, evidenciando o caráter elástico do modelo de consumo em nuvem.

Considerando os testes oficiais apresentados neste trabalho, bem como execuções adicionais realizadas para validação do comportamento da IA, estima-se que cada submissão (*submit*) apresentou um custo aproximado de US\$ 1,54, referente exclusivamente ao consumo dos serviços de Inteligência Artificial. Ressalta-se que esse valor não contempla custos adicionais de infraestrutura, como utilização de rede, processamento computacional, armazenamento em banco de dados e eventuais encargos ou variações cambiais, estando, por conseguinte, limitado ao custo direto de inferência dos modelos no período analisado.

10. Conclusão

Este trabalho investigou a aplicação de Inteligência Artificial Generativa no apoio à modelagem de ameaças em ambientes de computação em nuvem, utilizando a metodologia STRIDE e implementando um protótipo funcional em AWS. A pesquisa partiu da premissa de que a crescente complexidade das arquiteturas modernas exige abordagens mais automatizadas e escaláveis para análise de segurança.

A solução desenvolvida integrou conceitos teóricos de segurança, práticas de modelagem de ameaças e recursos avançados de IA resultando em um fluxo operacional capaz de apoiar a identificação de ativos, análise de riscos e proposição de ameaças de forma semi-automatizada. A implementação permitiu validar a viabilidade técnica da abordagem e observar seu comportamento em diferentes cenários, evidenciando capacidades e limitações.

A execução dos experimentos permitiu avaliar o comportamento da solução baseada em IA aplicada à modelagem de ameaças. O protótipo demonstrou consistência operacional, processando descrições arquiteturais e gerando saídas estruturadas com ativos, ameaças e classificações STRIDE.

Entre os principais achados, destaca-se a capacidade da IA de acelerar de modo expressivo a identificação inicial de ameaças, reduzindo o esforço manual nas etapas preliminares. A solução apresentou bom desempenho na generalização de padrões de risco em arquiteturas de nuvem, especialmente em cenários envolvendo APIs, armazenamento e processamento distribuído.

Todavia, foram observadas limitações importantes: geração de ameaças genéricas em alguns casos, ausência de contexto específico do negócio e dependência direta da qualidade dos prompts. Em cenários estruturados com descrições claras, os resultados foram mais precisos; em cenários ambíguos, a qualidade apresentou variações, reforçando a necessidade de entrada bem definida e revisão humana.

Os resultados indicam que a utilização de IA é tecnicamente viável e apresenta ganhos em eficiência e padronização, especialmente nas fases iniciais. Contudo, a solução ainda depende de supervisão especializada para garantir precisão e adequação aos requisitos específicos de segurança.

10.1. Comparação com abordagem manual

A comparação evidencia diferenças estruturais entre as abordagens. Enquanto o processo manual depende da experiência do analista e de etapas sequenciais, a IA permite geração rápida de artefatos iniciais, reduzindo com magnitude relevante o tempo necessário.

A IA deve ser compreendida como ferramenta de apoio, não como substituto. A validação, priorização e contextualização das ameaças ainda requerem conhecimento especializado. A atuação do analista permanece essencial para filtrar falsos positivos e garantir aplicabilidade prática.

A IA se destaca em ambientes com arquiteturas bem definidas, tarefas repetitivas e análises de larga escala. A análise manual é superior em cenários que exigem interpretação contextual profunda, entendimento de regras de negócio e avaliação crítica baseada em conhecimento tácito.

As abordagens são complementares: a IA contribui com velocidade, escala e padronização; a análise humana garante precisão, contexto e confiabilidade. O modelo híbrido, no qual a IA acelera o processo enquanto o especialista mantém controle sobre qualidade e relevância, apresenta-se como mais adequado.

10.2. Limitações do trabalho

Este trabalho apresenta limitações relacionadas ao desenho experimental, características dos cenários e natureza dos modelos de IA utilizados.

Quanto ao experimento, destaca-se o número restrito de cenários analisados em profundidade, reduzindo a abrangência estatística. A avaliação da qualidade das ameaças envolve subjetividade, dependendo da interpretação técnica do avaliador.

Os testes foram realizados em ambientes controlados com descrições arquiteturais estruturadas, podendo não refletir integralmente a complexidade de ambientes corporativos reais com heterogeneidade de sistemas, integrações legadas e requisitos específicos de negócio.

Os modelos de linguagem apresentam limitações inerentes: alucinações, sensibilidade à formulação de prompts e falta de conhecimento específico atualizado. O comportamento do modelo pode variar ao longo do tempo, impactando a reprodutibilidade dos resultados.

A solução não incorpora mecanismos avançados de validação automática ou integração com bases externas de conhecimento, como bancos de vulnerabilidades ou frameworks normativos, reforçando a necessidade de validação humana.

10.3. Trabalhos futuros

Diversas oportunidades de evolução podem aprimorar a robustez, precisão e aplicabilidade da abordagem proposta.

Na arquitetura, sugere-se incorporar mecanismos estruturados de entrada, como integração com diagramas formais (modelos C4, arquivos JSON/YAML de IaC), reduzindo ambiguidades. A adoção de pipelines automatizados integrando a solução a processos SSDLC permitiria execução contínua da modelagem ao longo do ciclo de vida das aplicações.

Por fim, abordagens híbridas mais sofisticadas, combinando IA com regras determinísticas, validações automáticas, outras fontes de dados externas e participação ativa de especialistas, equilibrariam ganhos de escala e velocidade com precisão e contexto.

10.4. Considerações finais

Este trabalho demonstrou a viabilidade técnica e operacional de utilizar Inteligência Artificial Generativa como mecanismo de apoio à modelagem de ameaças, evidenciando ganhos em tempo de execução, padronização e capacidade de análise inicial de riscos.

A IA auxiliou significativamente na identificação de ativos, categorização de ameaças segundo STRIDE e ampliação da cobertura de análise, reduzindo o esforço manual nas etapas iniciais. A abordagem proposta atende ao objetivo de apoiar a modelagem de ameaças, tornando o processo mais ágil e acessível.

Ainda assim, limitações importantes foram identificadas: geração de falsos positivos, dependência da qualidade dos insumos e ausência de compreensão aprofundada do contexto de negócio. Esses fatores reforçam que a IA deve ser tratada como componente complementar, não como substituta da análise humana.

A contribuição deste trabalho reside na abordagem aplicada que conecta conceitos acadêmicos de segurança da informação com utilização prática de tecnologias emergentes. A análise comparativa com abordagens manuais e a avaliação de custos evidenciam a viabilidade econômica e operacional da solução.

Conclui-se que a adoção de Inteligência Artificial na modelagem de ameaças representa avanço relevante, desde que implementada com critérios técnicos adequados e integrada a processos de validação humana. A combinação entre automação e expertise especializada apresenta-se como caminho promissor para evolução das práticas de segurança, permitindo maior eficiência sem comprometer qualidade e confiabilidade das análises.

Referências

AMAZON WEB SERVICES. **Aligning to the NIST Cybersecurity Framework in the AWS Cloud**. Disponível em: <https://aws.amazon.com/blogs/security/updated-whitepaper-available-aligning-to-the-nist-cybersecurity-framework-in-the-aws-cloud/>. Acesso em: 2 abr. 2026.

AMAZON WEB SERVICES. **AWS Cloud Development Kit (AWS CDK) v2**. Disponível em: <https://docs.aws.amazon.com/cdk/v2/guide/home.html>. Acesso em: 24 dez. 2025.

AMAZON WEB SERVICES. **AWS Lambda Powertools Python**. Disponível em: <https://docs.powertools.aws.dev/lambda/python/latest/>. Acesso em: 24 dez. 2025.

AMAZON WEB SERVICES. **AWS SDK for Python (Boto3)**. Disponível em: <https://aws.amazon.com/sdk-for-python/>. Acesso em: 24 dez. 2025.

AMAZON WEB SERVICES. **AWS Security Best Practices. AWS Whitepaper, 2022**. Disponível em: <https://docs.aws.amazon.com/whitepapers/latest/aws-security-best-practices/>. Acesso em: 24 dez. 2025.

AMAZON WEB SERVICES. **AWS Security Reference Architecture (AWS SRA) – core architecture**. Disponível em: <https://docs.aws.amazon.com/prescriptive-guidance/latest/security-reference-architecture/introduction.html>. Acesso em: 27 mar. 2026.

AMAZON WEB SERVICES. **AWS Shared Responsibility Model**. AWS Documentation, 2023. Disponível em: <https://aws.amazon.com/pt/compliance/shared-responsibility-model/>. Acesso em: 9 nov. 2025.

AMAZON WEB SERVICES. **AWS Well-Architected Framework: Security Pillar**. 2023.

AMAZON WEB SERVICES. **Brazil Data Privacy**. Disponível em: <https://aws.amazon.com/compliance/brazil-data-privacy/>. Acesso em: 25 jan. 2026.

AMAZON WEB SERVICES. **CDK-Nag: Check CDK applications for best practices**. Disponível em: <https://github.com/cdklabs/cdk-nag>. Acesso em: 24 dez. 2025.

AMAZON WEB SERVICES. **Navegando na conformidade com a LGPD na AWS**. Disponível em: https://d1.awsstatic.com/whitepapers/pt_BR/compliance/LGPD_Compliance_on_AWS.pdf. Acesso em: 3 fev. 2026.

AMAZON WEB SERVICES. **Práticas recomendadas de segurança no IAM**. Disponível em: https://docs.aws.amazon.com/pt_br/IAM/latest/UserGuide/best-practices.html. Acesso em: 14 fev. 2026.

AMAZON WEB SERVICES. **Security best practices for your VPC**. Disponível em: <https://docs.aws.amazon.com/vpc/latest/userguide/vpc-security-best-practices.html>. Acesso em: 28 fev. 2026.

AMAZON WEB SERVICES. **What is FinOps?** Disponível em: <https://aws.amazon.com/aws-cost-management/finops/>. Acesso em: 21 abr. 2026.

AMERSHI, S. et al. **Guidelines for Human-AI Interaction. In: CHI CONFERENCE ON HUMAN FACTORS IN COMPUTING SYSTEMS**, 2019. Proceedings [...]. [S.l.: s.n.], 2019. p. 1-13.

BARKER, E.; ROGINSKY, A. **Transitioning the Use of Cryptographic Algorithms and Key Lengths. NIST Special Publication 800-131A, Revision 2**, 2019. Disponível em: <https://csrc.nist.gov/publications/detail/sp/800-131a/rev-2/final>. Acesso em: 15 dez. 2024.

BERGER, B. J. et al. **Automatically extracting threats from extended data flow diagrams. In: INTERNATIONAL SYMPOSIUM ON ENGINEERING SECURE SOFTWARE AND SYSTEMS**. Proceedings [...]. Springer, 2016. p. 56-71.

BIGGIO, B.; ROLI, F. **Wild patterns: Ten years after the rise of adversarial machine learning**. Pattern Recognition, v. 84, p. 317-331, 2018.

BOYENS, J. et al. **Supply Chain Risk Management Practices for Federal Information Systems and Organizations. NIST Special Publication 800-161**, 2015. Disponível em: <https://csrc.nist.gov/publications/detail/sp/800-161/final>. Acesso em: 23 fev. 2026.

BRASIL. **Lei nº 13.709, de 14 de agosto de 2018**. Dispõe sobre a proteção de dados pessoais. Diário Oficial da União: Brasília, DF, 15 ago. 2018. Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm. Acesso em: 7 nov. 2025.

BROWN, T. et al. **Language Models are Few-Shot Learners. In: ADVANCES IN NEURAL INFORMATION PROCESSING SYSTEMS (NEURIPS)**, v. 33, 2020. Proceedings [...]. [S.l.: s.n.], 2020. p. 1877-1901.

BRUNDAGE, M. et al. **The Malicious Use of Artificial Intelligence: Forecasting, Prevention, and Mitigation**. Future of Humanity Institute, University of Oxford, 2018. Disponível em: <https://arxiv.org/abs/1802.07228>. Acesso em: 04 jan. 2026.

BUCZAK, A. L.; GUVEN, E. **A Survey of Data Mining and Machine Learning Methods for Cyber Security Intrusion Detection**. IEEE Communications Surveys & Tutorials, v. 18, n. 2, p. 1153-1176, 2016.

CHANDOLA, V.; BANERJEE, A.; KUMAR, V. **Anomaly detection: A survey. ACM Computing Surveys**, v. 41, n. 3, p. 1-58, 2009.

CLOUD SECURITY ALLIANCE. **Top Threats to Cloud Computing: Pandemic Eleven**. 2023.

COMBE, T. et al. **To Docker or Not to Docker: A Security Perspective**. IEEE Cloud Computing, v. 3, n. 5, p. 54-62, 2016.

CORFIELD, Gareth. **Kids' gaming website Animal Jam breached after miscreants spot private AWS key on Slack channel**. Disponível em:

https://www.theregister.com/2020/11/12/animal_jam_breached/. Acesso em: 22 mar. 2026.

DEMARCO, T. **Structured Analysis and System Specification**. Yourdon Press, 1979.

ENISA. **Artificial Intelligence and Cybersecurity: Challenges and Opportunities**. 2023.

FERRAILOLO, D. F.; KUHN, D. R. **Role-Based Access Controls**. In: 15TH NATIONAL COMPUTER SECURITY CONFERENCE, 2009. Proceedings [...]. [S.l.: s.n.], 2009. p. 554-563.

FERNANDES, D. A. B. et al. **Security issues in cloud environments: a survey**. International Journal of Information Security, v. 13, n. 2, p. 113-170, 2014.

GARTNER. **Top Security and Risk Management Trends for 2023**. Disponível em: <https://www.gartner.com/en/articles/top-security-and-risk-management-trends>. Acesso em: 15 dez. 2024.

GOODFELLOW, Ian; BENGIO, Yoshua; COURVILLE, Aaron. **Deep Learning**. Cambridge: MIT Press, 2016.

GUNASEKAR, S. et al. **Textbooks Are All You Need**. arXiv preprint arXiv:2306.11644, 2023.

HOWARD, M.; LIPNER, S. **The Security Development Lifecycle**. Microsoft Press, 2006.

IBM CORPORATION. **What is Identity and Access Management (IAM)?** Disponível em: <https://www.ibm.com/br-pt/think/topics/identity-access-management>. Acesso em: 7 nov. 2025.

IBM. **Quais são os benefícios da computação em nuvem?** Disponível em: <https://www.ibm.com/br-pt/think/topics/cloud-computing-benefits>. Acesso em: 12 jan. 2026.

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. ISO/IEC 27001: **Information security, cybersecurity and privacy protection - Information security management systems - Requirements**. 2022.

Jl, Z. et al. **Survey of Hallucination in Natural Language Generation**. ACM Computing Surveys, v. 55, n. 12, p. 1-38, 2023.

JIANG, A. Q. et al. **Mistral 7B**. arXiv preprint arXiv:2310.06825, 2023.

KENT, K.; SOUPPAYA, M. **Guide to Computer Security Log Management**. NIST Special Publication 800-92, 2006. Disponível em: <https://csrc.nist.gov/publications/detail/sp/800-92/final>. Acesso em: 15 Jan. 2026.

KOHNFELDER, L.; GARG, P. **The threats to our products**. Microsoft Interface, Microsoft Corporation, 1999.

MANEPALLI, Srinivas. **Building end-to-end AWS DevSecOps CI/CD pipeline**. AWS DevOps Blog, 2021. Disponível em: <https://aws.amazon.com/blogs/devops/building-end-to-end-aws-devsecops-ci-cd-pipeline-with-open-source-sca-sast-and-dast-tools/>. Acesso em: 7

nov. 2025.

McGRAW, G. **Software Security: Building Security In**. Addison-Wesley Professional, 2006.

MEAD, N. R.; STEHNEY, T. **Security quality requirements engineering (SQUARE) methodology**. ACM SIGSOFT Software Engineering Notes, v. 30, n. 4, p. 1-7, 2005.

MELL, P.; GRANCE, T. **The NIST Definition of Cloud Computing**. National Institute of Standards and Technology, Special Publication 800-145, 2011. Disponível em: <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-145.pdf>. Acesso em: 15 dez. 2024.

MELL, P.; SCARFONE, K.; ROMANOSKY, S. **A Complete Guide to the Common Vulnerability Scoring System Version 2.0**. NIST, 2007. Disponível em: <https://www.first.org/cvss/v2/guide>. Acesso em: 27 dez. 2025.

META. React: **The library for web and native user interfaces**. Disponível em: <https://react.dev/>. Acesso em: 11 dez. 2025.

MICROSOFT. **TypeScript: JavaScript With Syntax For Types**. Disponível em: <https://www.typescriptlang.org/>. Acesso em: 21 dez. 2025.

MODI, C. et al. **A survey of intrusion detection techniques in Cloud**. Journal of Network and Computer Applications, v. 36, n. 1, p. 42-57, 2013.

MOSQUEIRA-REY, E. et al. **Human-in-the-loop machine learning: A state of the art**. Artificial Intelligence Review, v. 56, p. 3005-3054, 2023.

MYAGMAR, S.; LEE, A. J.; YURCIK, W. **Threat modeling as a basis for security requirements**. In: SYMPOSIUM ON REQUIREMENTS ENGINEERING FOR INFORMATION SECURITY (SREIS), 2005. Proceedings [...]. [S.l.: s.n.], 2005. p. 1-8.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. **Artificial Intelligence Risk Management Framework (AI RMF 1.0)**. Gaithersburg, 2023.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. **Framework for Improving Critical Infrastructure Cybersecurity**. Version 1.1. Gaithersburg, 2018. Disponível em: <https://www.nist.gov/cyberframework>. Acesso em: 29 set. 2025.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. **Security and Privacy Controls for Information Systems and Organizations**. NIST Special Publication 800-53, Revision 5, 2020. Disponível em: <https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>. Acesso em: 25 dez. 2025.

NATIONAL SECURITY AGENCY. **Defense in Depth: A practical strategy for achieving Information Assurance in today's highly networked environments**. 2010. Disponível em: <https://www.nsa.gov/portals/75/documents/what-we-do/cybersecurity/professional-resources/csi-defense-in-depth.pdf>. Acesso em: 25 dez. 2025.

NEWMAN, S. **Building Microservices: Designing Fine-Grained Systems**. O'Reilly Media, 2015.

OPEN WEB APPLICATION SECURITY PROJECT. **Threat Modeling**. 2021. Disponível em: https://owasp.org/www-community/Threat_Modeling. Acesso em: 18 fev. 2026.

OPEN WEB APPLICATION SECURITY PROJECT. **Top 10 for Large Language Model Applications**. 2023. Disponível em: <https://owasp.org/www-project-top-10-for-large-language-model-applications/>. Acesso em: 14 abr. 2026.

OPENAI. **GPT-4 Technical Report**. arXiv preprint arXiv:2303.08774, 2023.

PAPERNOT, N. et al. **Towards the Science of Security and Privacy in Machine Learning**. arXiv preprint arXiv:1611.03814, 2016. Disponível em: <https://arxiv.org/abs/1611.03814>. Acesso em: 15 dez. 2025.

PIAS, Jaiana. Cibersegurança em 2025. **InterOp, 2025**. Disponível em: <https://interop.com.br/2025/02/ciberseguranca-em-2025-18-tipos-de-ataques-ciberneticos-em-alta/>. Acesso em: 7 nov. 2025.

PRICEWATERHOUSECOOPERS. **Pesquisa Global sobre Transformação Digital 2025**. São Paulo, 2025. Disponível em: <https://www.pwc.com.br>. Acesso em: 29 set. 2025.

PYDANTIC. **Pydantic: Data validation using Python type hints**. Disponível em: <https://docs.pydantic.dev/>. Acesso em: 15 dez. 2025.

PYNAMODB. **PynamoDB Documentation**. Disponível em: <https://pynamodb.readthedocs.io/>. Acesso em: 15 dez. 2025.

REMIX. **React Router: Declarative routing for React**. Disponível em: <https://reactrouter.com/>. Acesso em: 20 dez. 2025.

RUSSELL, Stuart; NORVIG, Peter. **Artificial Intelligence: A Modern Approach**. 4. ed. Hoboken: Pearson, 2021.

SALTZER, J. H.; SCHROEDER, M. D. **The protection of information in computer systems**. Proceedings of the IEEE, v. 63, n. 9, p. 1278-1308, 1975.

SCANDARIATO, R. et al. **Predicting vulnerable software components via text mining**. IEEE Transactions on Software Engineering, v. 40, n. 10, p. 993-1006, 2015.

SCARFONE, K.; MELL, P. **Guide to Intrusion Detection and Prevention Systems (IDPS)**. NIST Special Publication 800-94, 2007. Disponível em: <https://csrc.nist.gov/publications/detail/sp/800-94/final>. Acesso em: 20 dez. 2025.

SHARMA, Tarun et al. **Security Automation and SOAR: Emerging Trends in Cyber Defense**. 2020.

SHEVCHENKO, N. et al. **Threat Modeling: A Summary of Available Methods**. Carnegie Mellon University, Software Engineering Institute, 2018. Disponível em:

<https://resources.sei.cmu.edu/library/asset-view.cfm?assetid=524448>. Acesso em: 15 dez. 2025.

SHNEIDERMAN, B. **Human-Centered Artificial Intelligence: Reliable, Safe & Trustworthy**. International Journal of Human-Computer Interaction, v. 36, n. 6, p. 495-504, 2020.

SHOSTACK, Adam. **Experiences threat modeling at Microsoft**. In: MODSEC@MODELS, 2008. Proceedings [...]. [S.l.: s.n.], 2008. p. 35-43.

SHOSTACK, Adam. **Threat Modeling: Designing for Security**. Indianapolis: Wiley, 2014.

SINGH, A.; SHRIVASTAVA, M. **Overview of Security issues in Cloud Computing**. International Journal of Advanced Computer Research, v. 2, n. 1, p. 41-45, 2012.

SION, L. et al. **Automated threat modeling for serverless applications**. International Journal of Information Security, 2022. Disponível em: <https://link.springer.com/article/10.1007/s10207-025-01094-0>. Acesso em: 15 dez. 2025.

SION, L. et al. Solution-based threat modeling: A strategic approach. IEEE Security & Privacy, v. 18, n. 1, p. 8-15, 2020.

SOMMER, Robin; PAXSON, Vern. **Outside the closed world**. In: IEEE SYMPOSIUM ON SECURITY AND PRIVACY, 2010. Proceedings [...]. [S.l.: s.n.], 2010. p. 305-316.

STALLINGS, W.; BROWN, L. **Computer Security: Principles and Practice**. 4. ed. Pearson, 2018.

STONEBURNER, G.; GOGUEN, A.; FERLINGA, A. **Risk Management Guide for Information Technology Systems**. NIST Special Publication 800-30, 2002. Disponível em: <https://csrc.nist.gov/publications/detail/sp/800-30/archive/2002-07-01>. Acesso em: 15 dez. 2025.

STOUFFER, K. et al. **Guide to Industrial Control Systems (ICS) Security**. NIST Special Publication 800-82, Revision 2, 2015. Disponível em: <https://csrc.nist.gov/publications/detail/sp/800-82/rev-2/final>. Acesso em: 15 dez. 2025.

SUBASHINI, S.; KAVITHA, V. **A survey on security issues in service delivery models of cloud computing**. Journal of Network and Computer Applications, v. 34, n. 1, p. 1-11, 2011.

SWANSON, M. et al. **Contingency Planning Guide for Federal Information Systems**. NIST Special Publication 800-34, Revision 1, 2002. Disponível em: <https://csrc.nist.gov/publications/detail/sp/800-34/rev-1/final>. Acesso em: 15 dez. 2025.

TAILWIND LABS. **Tailwind CSS: A utility-first CSS framework**. Disponível em: <https://tailwindcss.com/>. Acesso em: 15 dez. 2025.

TORR, P. **Demystifying the threat modeling process**. IEEE Security & Privacy, v. 3, n. 5, p. 66-70, 2015.

TOUVRON, H. et al. **Llama 2: Open Foundation and Fine-Tuned Chat Models**. arXiv preprint arXiv:2307.09288, 2023.

TUMA, K. et al. **Two architectural threat analysis techniques compared**. In: **EUROPEAN CONFERENCE ON SOFTWARE ARCHITECTURE**. Proceedings [...]. Springer, 2018. p. 347-363.

TWILIO. **Incident Report: TaskRouter JS SDK Security Incident** – July 19, 2020. Disponível em: <https://www.twilio.com/en-us/blog/company/communications/incident-report-taskrouter-js-sdk-july-2020>. Acesso em: 5 abr. 2026.

UZUNOV, A. V.; FERNANDEZ, E. B.; FALKNER, K. **Securing distributed systems using patterns: A survey**. **Computers & Security**, v. 31, n. 5, p. 681-703, 2012.

VASWANI, Ashish et al. **Attention is all you need**. In: **NEURIPS**, 2017. Proceedings [...]. [S.l.: s.n.], 2017.

VITE. **Vite: Next Generation Frontend Tooling**. Disponível em: <https://vitejs.dev/>. Acesso em: 15 dez. 2015.

WHITMAN, M. E.; MATTORD, H. J. **Principles of Information Security**. 7. ed. Cengage Learning, 2021.

WILSON, M.; HASH, J. **Building an Information Technology Security Awareness and Training Program**. **NIST Special Publication 800-50**, 2003. Disponível em: <https://csrc.nist.gov/publications/detail/sp/800-50/final>. Acesso em: 15 dez. 2024.

WINKLER, V. **Securing the Cloud: Cloud Computer Security Techniques and Tactics**. Syngress, 2011.

XIONG, W.; LAGERSTRÖM, R. **Threat modeling – A systematic literature review**. **Computers & Security**, v. 84, p. 53-69, 2019.

YAZMYRADOV, S.; LEE, HoonJae. **A Comprehensive Review of AI Security**. IJIBC, 2024.

YOURDON, E.; CONSTANTINE, L. L. **Structured Design: Fundamentals of a Discipline of Computer Program and Systems Design**. Prentice-Hall, 1979.

ZHANG, Y. et al. **Siren's Song in the AI Ocean: A Survey on Hallucination in Large Language Models**. arXiv preprint arXiv:2309.01219, 2023. Disponível em: <https://arxiv.org/abs/2309.01219>. Acesso em: 09 dez. 2025.

Apêndice A - Guia de Implementação e Execução do Protótipo de Modelagem de Ameaças com IA Generativa

A.1. Visão Geral do Protótipo

O protótipo desenvolvido tem como objetivo apoiar a modelagem de ameaças utilizando Inteligência Artificial Generativa, com base na metodologia STRIDE, em um ambiente de computação em nuvem.

A solução é composta por duas camadas principais:

- *Back-end*: responsável pelo processamento das requisições, integração com serviços AWS e execução dos modelos de IA.
- *Front-end*: interface web para interação do usuário, visualização de resultados e envio de dados.

A arquitetura utiliza serviços gerenciados da AWS, incluindo:

- AWS Lambda;
- Amazon S3;
- Amazon CloudFront;
- Amazon Cognito;
- AWS AppSync (GraphQL);
- Amazon Bedrock (modelos de IA).

A.2. Pré-requisitos do Ambiente

Para execução do protótipo, são necessários os seguintes requisitos:

Infraestrutura

- Instância EC2 (mínimo recomendado: t2.medium, 30GB EBS);
- Região AWS: us-east-1 (Norte da Virgínia).

Permissões

A instância deve possuir uma função IAM com permissões administrativas para:

- EC2, ECS, ECR;
- S3, RDS;
- CloudFormation;
- IAM;

Observação: embora permissões amplas tenham sido utilizadas no protótipo, em ambientes produtivos recomenda-se aplicar o princípio do menor privilégio.

Dependências:

- a) Python $\geq$ 3.11;

- b) Node.js $\geq$ 18;
- c) Docker;
- d) Git;
- e) AWS CLI;
- f) AWS CDK v2;

Além disso, é necessário que o ambiente possua credenciais válidas configuradas para acesso à conta AWS.

A.3. Implantação do Back-end

A.3.1. Preparação do Ambiente

O código-fonte do projeto deve ser obtido via repositório Git:

- Clonagem do repositório;
- Criação de ambiente virtual Python;
- Instalação das dependências do projeto.

A utilização de ambiente virtual é recomendada para isolamento de dependências e controle de versão.

A.3.2. Configuração de Serviços AWS

Antes da implantação, é necessário:

- Autenticar no Amazon ECR (para uso de containers);
- Validar credenciais AWS;
- Executar o processo de *bootstrap* do AWS CDK (caso ainda não realizado).

A.3.3. Implantação da Infraestrutura

A infraestrutura é provisionada via AWS CDK, utilizando CloudFormation.

O processo inclui:

- Geração dos *templates* (*synth*);
- Implantação automatizada dos recursos (*deploy*).

Após a implantação, são gerados outputs essenciais, incluindo:

- Endpoint GraphQL;
- Identificadores do Cognito;
- Nome do bucket S3.

Esses dados são necessários para a configuração do front-end.

A.3.4. Integração com Modelos de IA

O protótipo utiliza modelos disponíveis no Amazon Bedrock, incluindo:

- Claude 4 Sonnet;
- Claude 4.5 Sonnet;
- Claude 4 Haiku.

É necessário habilitar previamente o acesso aos modelos na conta AWS.

A.4. Configuração do Mecanismo de Modelagem (*Few-Shot Learning*)

O processo de modelagem de ameaças utiliza técnica de *Few-Shot Prompting* para interpretação de diagramas arquiteturais.

Para isso, é necessário:

- Inserir exemplos de diagramas no formato de imagem;
- Fornecer descrições correspondentes em formato textual (DFD).

Esses pares devem ser armazenados no bucket S3 em estrutura padronizada.

Limitação relevante: a ausência desses exemplos impede o funcionamento adequado do sistema, sem geração explícita de erro no *front-end*.

A.5. Implantação do Front-end

A.5.1. Configuração do Ambiente

O *front-end* é baseado em:

- React;
- Vite;

A configuração depende diretamente das saídas do *back-end*, sendo necessário definir variáveis de ambiente, incluindo:

- Região AWS, que deve ser “US-EAST-1”;
- IDs do Cognito;
- Endpoint GraphQL;
- Nome do bucket S3.

A.5.2. Execução Local

O ambiente pode ser executado em modo de desenvolvimento, permitindo:

- *Hot reload*;
- Depuração em tempo real;
- Testes iterativos.

O acesso é realizado via navegador na porta configurada (ex.: 5173).

A.5.3. Implantação em Produção

A implantação do front-end também é realizada via AWS CDK, utilizando:

- Amazon S3 (armazenamento estático);
- Amazon CloudFront (distribuição);
- AWS WAF (proteção).

A aplicação final é disponibilizada por meio de uma URL pública gerada ao final do processo.

A.6. Atualização e Manutenção

Caso haja alterações no esquema GraphQL do *back-end*, é necessário:

- Atualizar os *statements*;
- Gerar novos tipos para o front-end.

Esse processo garante consistência entre as camadas da aplicação.

A.7. Testes

O protótipo permite execução de testes unitários no *back-end*, contribuindo para validação funcional e estabilidade da aplicação.

Apêndice B - Disponibilização do Conjunto Completo dos Dados gerados nas 4 amostras representativas

Devido ao volume elevado de dados gerados durante os experimentos, especialmente os dados de saída produzidos pelos modelos de IA, que totalizam mais de 400 registros em apenas um arquivo, optou-se por não incluir integralmente esse material no corpo deste trabalho, a fim de preservar a clareza, organização e a objetividade do documento.

Com o objetivo de garantir transparência, rastreabilidade e reprodutibilidade dos experimentos, o conjunto completo de dados encontra-se disponível em repositório externo, podendo ser acessado por meio do seguinte link:

<https://drive.google.com/drive/folders/14JKcyEU-crdQ7CDL2QvvQXrqgTDk8tJf?hl=pt-br>

O material disponibilizado inclui:

- dados brutos de saída;
- estrutura utilizada para consolidação das métricas analisadas.

Apêndice C - Disponibilização dos Dados Detalhados de Custos

Devido ao volume e à complexidade dessas informações, optou-se por não incluir integralmente esses dados no corpo deste trabalho, a fim de preservar a clareza, legibilidade e objetividade da análise apresentada.

Para garantir transparência e possibilitar a reprodutibilidade das análises, o conjunto completo de dados de custos encontra-se disponível em repositório externo, acessível por meio do seguinte link:

<https://drive.google.com/drive/folders/1Mf9UB-nqt8KlJkSSJEm2EDpfmeGjcVaC?hl=pt-br>

O material disponibilizado inclui:

- relatórios completos de custos por serviço;
- detalhamento de consumo por recurso.